



INSTRUCTIVO

CLÁUSULAS DE PROTECCIÓN DE DATOS Y SEGURIDAD DE LA INFORMACIÓN PARA CONTRATOS DE TECNOLOGÍAS DEL SECTOR SALUD

Sistema de Gestión de Seguridad de la Información - MINSAL

ITS-NC- 006

Versión Oficial Actual v05 - Marzo 2025

	Responsable	Fecha	Firma
Elaborado		01.04.2025 01.04.2025	
Revisado		01.04.2025	
Aprobado		02.04.2025	



INSTRUCTIVO SOBRE CLÁUSULAS DE PROTECCIÓN DE DATOS Y SEGURIDAD DE LA INFORMACIÓN DEL SECTOR SALUD

	Sistema de Gestión de Seguridad de la Información - Minsal			
	MINISTERIO DE SALUD	ITS-NC- 006	Versión: 5	Página 2 de 46 TLP:BLANCO

ÍNDICE

1. PREAMBULO.....	3
2. CUMPLIMIENTO.....	4
3. DEFINICIONES.....	4
4. CUMPLIMIENTO DE LAS POLÍTICAS Y PROCEDIMIENTOS VIGENTES DE SEGURIDAD DE LA INFORMACIÓN DEL SECTOR SALUD.....	7
5. GESTION DE SEGURIDAD.....	8
6. PROPIEDAD INTELECTUAL.....	14
7. ALOJAMIENTO DE DATOS EN SERVIDORES Y USO DE CLOUD COMPUTING.....	16
8. OBLIGACIONES DE SEGURIDAD PARA SOLUCIONES DE SOFTWARE COMO SERVICIO (SAAS) 24	
9. HERRAMIENTAS DE SEGURIDAD.....	30
10. INFRAESTRUCTURA PARA PRODUCCIÓN.....	31
11. GESTIÓN DE DATOS PRODUCTIVOS.....	32
12. ARQUITECTURA REFERENCIAL.....	38
13. INTEROPERABILIDAD.....	39
14. USO DE INTELIGENCIA ARTIFICIAL (IA).....	40
15. ENTREGA DE SISTEMAS Y DATOS AL TÉRMINO DEL CONTRATO.....	41
16. NORMATIVA SOBRE SEGURIDAD DE LA INFORMACION.....	42
17. MECANISMO DE DIFUSIÓN.....	46
18. HISTORIAL Y CONTROL DE VERSIONES.....	46





1. PREAMBULO.

En el contexto actual de Transformación Digital de Estado, la adopción de tecnologías avanzadas y la integración de soluciones en la nube han incrementado significativamente la dependencia de proveedores tecnológicos. Sin embargo, esta evolución también ha traído consigo nuevos riesgos, entre los cuales destacan los ataques a la cadena de suministro, los cuales han demostrado ser una de las principales amenazas en materia de ciberseguridad, ya que permiten a actores malintencionados comprometer sistemas críticos a través de terceros, como proveedores de software, servicios en la nube o infraestructura tecnológica.

En el Sector Salud, este tipo de ataques puede tener consecuencias devastadoras, desde la filtración de datos sensibles de pacientes hasta la interrupción de servicios esenciales, comprometiendo la disponibilidad y confidencialidad de la información sanitaria que es crítica para la continuidad del cuidado de los pacientes.

Ejemplos recientes de este tipo de amenaza es el ataque a SolarWinds en 2020, que permitió a actores malintencionados infiltrarse en diversas agencias gubernamentales de Estados Unidos y empresas privadas a nivel mundial. En Chile, instituciones gubernamentales y de infraestructura crítica también han sido blanco de ataques a la cadena de suministro, como lo evidencian los incidentes registrados en organismos como el Servicio de Impuestos Internos (SII), el Poder Judicial y la Dirección de Compras y Contratación Pública, donde vulnerabilidades en proveedores tecnológicos comprometieron la seguridad de datos sensibles.

Dado este escenario, es fundamental fortalecer los contratos tecnológicos mediante cláusulas específicas de protección de datos y seguridad de la información, estableciendo controles y medidas que mitiguen el impacto de posibles vulnerabilidades en los servicios contratados.

Estas cláusulas deben garantizar que los proveedores cumplan con estándares internacionales de seguridad, así como con las disposiciones establecidas en la Ley N° 21.663 sobre Ciberseguridad. Además, deberán alinearse con la normativa de seguridad definida por el Ministerio de Salud (Minsal), en especial con la Política General de Seguridad de la Información y Ciberseguridad, aprobada mediante Resolución Exenta N° 1465/2023. Asimismo, los proveedores deberán cumplir con la Ley N° 19.628 sobre Protección de la Vida Privada, su actualización a través de la Ley N° 21.719 sobre Protección de Datos Personales, y la Ley N° 20.584 de Derechos y Deberes de los pacientes, modificada por Ley N° 21.541 sobre Telemedicina, y Ley N° 21.668 de Interoperabilidad de Fichas Clínicas, garantizando el resguardo, acceso expedito y la confidencialidad de la información en todos los procesos que involucren el tratamiento de datos personales y de salud.

El presente Instructivo de Cláusulas de Protección de Datos y Seguridad de la Información tiene como objetivo proporcionar lineamientos claros para la inclusión de requisitos de





seguridad en los contratos tecnológicos del sector salud. Su propósito es garantizar que los proveedores adopten prácticas adecuadas en la gestión de riesgos, protejan la confidencialidad e integridad de la información, y contribuyan a la resiliencia digital de las instituciones del Sector de Salud. A través de estas cláusulas, se busca no solo el cumplimiento normativo, sino también el fortalecimiento de la seguridad en toda la cadena de suministro tecnológica, asegurando la confianza y la continuidad operativa en los servicios de salud.

2. CUMPLIMIENTO.

Las disposiciones de este documento serán de cumplimiento obligatorio para todos los proveedores tecnológicos que suscriban contratos con el Ministerio de Salud (Minsal) y el Sector Salud, en función de la naturaleza y alcance de cada proyecto. El cumplimiento de estos requisitos es esencial para garantizar la protección de la información crítica, la continuidad operativa y la resiliencia de la infraestructura tecnológica del sistema de salud.

Todos los proveedores deberán adherirse estrictamente a las Políticas y Procedimientos de Seguridad de la Información vigentes del Ministerio, asegurando el resguardo de los datos sensibles y los sistemas tecnológicos involucrados.

Asimismo, el proveedor, en su calidad de mandatario, tendrá prohibido retener, utilizar o compartir la información procesada, almacenada o transmitida en el marco del contrato para cualquier propósito ajeno a los términos acordados. Cualquier uso indebido, acceso no autorizado o retención de datos fuera del período estipulado será considerado una infracción grave, sujeta a sanciones contractuales y legales.

Al finalizar el contrato, el proveedor deberá eliminar o devolver toda la información de manera segura, aplicando mecanismos de eliminación certificados conforme a la normativa vigente.

3. DEFINICIONES.

Para los efectos de la aplicación de este documento, los términos que a continuación se señalan tendrán el significado que se indica:

- **Activos de información:** toda información o recurso relacionado para la creación, almacenamiento, gestión o transmisión de dicha información. Podrán ser activos materiales (RRHH especializados, aparatos, equipos, redes, instalaciones, soportes y sistemas de almacenamiento) o intangibles (datos, aplicaciones, sistemas operativos, bases de datos, imagen, reputación, marcas de la organización).
- **Activo informático:** toda información almacenada en una red y sistema informático que tenga valor para una persona u organización.
- **Autenticación:** propiedad de la información que da cuenta de su origen legítimo.





- **Anonimización:** procedimiento irreversible en virtud del cual un dato personal no puede vincularse o asociarse a una persona determinada, ni permitir su identificación, por haberse destruido o eliminado el nexo con la información que vincula, asocia o identifica a esa persona. Un dato anonimizado deja de ser un dato personal.
- **Agencia:** la Agencia Nacional de Ciberseguridad, que se conocerá en forma abreviada como ANCI.
- **Auditorías de seguridad:** procesos de control destinados a revisar el cumplimiento de las políticas y procedimientos que se derivan del Sistema de Gestión de la Seguridad de la Información.
- **Seudonimización:** tratamiento de datos personales que se efectúa de manera tal que ya no puedan atribuirse a un titular sin utilizar información adicional que permita la re-identificación, la cual debe constar en medios seguros, gestionados por separado, y estar sujeta a medidas técnicas y organizativas destinadas a garantizar que accedan a ella personas sólo personal autorizado por el responsable del tratamiento.
- **Ciberespacio:** El ciberespacio es un ambiente complejo, soportado por hardware y las redes de comunicaciones, en el cual constan interacciones entre personas, software y servicios de Internet, destinados a la distribución mundial de información y comunicación" (ISO 27032).
- **Ciberataque:** Acción realizada con la finalidad de destruir, exponer, alterar, deshabilitar, o exfiltrar u obtener acceso o hacer uso no autorizado de un activo informático.
- **Ciberseguridad:** Preservación de la confidencialidad e integridad de la información y de la disponibilidad y resiliencia de las redes y sistemas informáticos, con el objetivo de proteger a las personas, la sociedad, las organizaciones o las naciones de incidentes de ciberseguridad.
- **Incidente de ciberseguridad:** Todo evento que perjudique o comprometa la confidencialidad o integridad de la información, la disponibilidad o resiliencia de las redes y sistemas informáticos, o la autenticación de los procesos ejecutados o implementados en las redes y sistemas informáticos.
- **Confidencialidad:** Propiedad que consiste en que la información no es accedida o entregada a individuos, entidades o procesos no autorizados.
- **Continuidad de servicios:** Capacidad de un organización para mantener la disponibilidad de sus servicios, reduciendo el riesgo de eventos que puedan dar lugar a una interrupción o inestabilidad en las operaciones de la entidad, manteniendo niveles aceptables de servicios, entendiendo por tales, las prestaciones básicas del sistema que sustentan las operaciones esenciales del servicios y propiciando la recuperación del nivel normal de servicios de tecnologías de la información (TI) en el menor tiempo posible.
- **Disponibilidad:** Propiedad que consiste en que la información es accesible y utilizable cuando es requerida por un individuo, entidad o proceso autorizado.





- **Datos Personales o datos de carácter personal:** los datos relativos a cualquier información concerniente a personas naturales, identificadas o identificables, con independencia de su soporte.
- **Datos Sensibles:** Datos personales que se refieren a características físicas o morales de las personas o a hechos o circunstancias de su vida privada o intimidad, entre otros, los hábitos personales, origen racial, las ideologías y opiniones políticas, las creencias o convicciones religiosas, los estados de salud físicos o psíquicos y la vida sexual.¹
- **Equipo de Respuesta a Incidentes de Seguridad Informática o CSIRT:** Centros multidisciplinarios que tienen por objeto prevenir, detectar, gestionar y responder a incidentes de ciberseguridad o ciberataques, en forma rápida y efectiva, y que actúan conforme a procedimientos y políticas predefinidas, ayudando a mitigar sus efectos.
- **Gestión de incidentes:** Procedimientos para la detección, análisis, manejo, contención y resolución de un incidente de ciberseguridad y responder ante ésta.
- **Incidente:** Evento inesperado o no deseado con consecuencias en detrimento de la seguridad de las redes, equipos y sistemas de información (véase también ciberincidente).
- **Infraestructura crítica:** las instalaciones, sistemas físicos o servicios esenciales y de utilidad pública, redes, servicios y equipos físicos y de tecnología de la información cuya afectación, degradación, denegación, interrupción o destrucción cause un grave daño a la salud o al abastecimiento de la población, a la actividad económica esencial, al medioambiente o a la seguridad del país. Se entiende por este concepto la infraestructura indispensable para la generación, transmisión, transporte, producción, almacenamiento y distribución de los servicios e insumos básicos para la población, tales como energía, gas, agua o telecomunicaciones; la relativa a la conexión vial, aérea, terrestre, marítima, portuaria o ferroviaria, y la correspondiente a servicios de utilidad pública, como los sistemas de asistencia sanitaria o de salud.
- **Integridad:** Propiedad que consiste en que la información no ha sido modificada o destruida sin autorización.
- **Nube privada:** La infraestructura de la nube se aprovisiona para uso exclusivo de una única organización aun cuando comprenda múltiples unidades de dicha organización. Puede ser propiedad, administrado y operado por la organización, un tercero o una combinación de ellos, y puede existir dentro o fuera de las instalaciones de la organización.
- **Nube pública:** La infraestructura y los recursos lógicos que forman parte del entorno se encuentran disponibles para el público en general a través de Internet. Suele ser propiedad

¹ La ley 21.719, que entrará en vigor el 01 de diciembre de 2026, sustituye la definición de datos sensibles por la siguiente: "Datos personales sensibles: tendrán esta condición aquellos datos personales que se refieren a las características físicas o morales de las personas o a hechos o circunstancias de su vida privada o intimidad, que revelen el origen étnico o racial, la afiliación política, sindical o gremial, la situación socioeconómica, las convicciones ideológicas o filosóficas, las creencias religiosas, los datos relativos a la salud, al perfil biológico humano, los datos biométricos, y la información relativa a la vida sexual, a la orientación sexual y a la identidad de género de una persona natural".



de un Prestador de Servicios que gestiona la infraestructura y el servicio o servicios que se ofrecen.

- **Protección de los activos de información:** Adopción de las medidas que resguarden la seguridad física de los dispositivos, así como los accesos a éstos.
- **Red y sistema informático:** conjunto de dispositivos, cables, enlaces, enrutadores u otros equipos de comunicaciones o sistemas que almacenen, procesen o transmitan datos digitales.
- **Resiliencia:** Capacidad de las redes y sistemas informáticos para seguir operando luego de un incidente de ciberseguridad, aunque sea en un estado degradado, debilitado o segmentado, y la capacidad de las redes y sistemas informáticos para recuperar sus funciones después de un incidente de ciberseguridad.
- **Riesgo:** posibilidad de ocurrencia de un incidente de ciberseguridad; la magnitud de un riesgo es cuantificada en términos de la probabilidad de ocurrencia del incidente y del impacto de las consecuencias de este.
- **Riesgo de Ciberseguridad:** Toda circunstancia o hecho razonablemente identificable y previsible, que tenga un posible efecto adverso en la seguridad de las redes, equipos y sistemas de información. Se puede cuantificar como la probabilidad de materialización de una de las amenazas antes mencionadas que produzca un impacto en términos de operatividad, o de integridad, confidencialidad o disponibilidad de datos.
- **Seguridad de la información:** Conjunto de medidas preventivas y reactivas de los organismos administradores y sus respectivos sistemas tecnológicos, que tienen por objeto resguardar y proteger la información, asegurando la confidencialidad, integridad, autenticidad y disponibilidad de los datos, continuidad de servicios y protección de activos de información.
- **Tratamiento de datos:** cualquier operación o conjunto de operaciones o procedimientos técnicos, de carácter automatizado o no, que permitan de cualquier forma recolectar, procesar, almacenar, comunicar, transmitir o utilizar datos personales o conjuntos de datos personales.
- **Vulnerabilidad:** Debilidad de un activo o control que puede ser explotado por una o más amenazas informáticas.

4. CUMPLIMIENTO DE LAS POLÍTICAS Y PROCEDIMIENTOS VIGENTES DE SEGURIDAD DE LA INFORMACIÓN DEL SECTOR SALUD.

Todo oferente, funcionario y proveedor del Sector Salud debe conocer y dar cumplimiento a las Políticas y Procedimientos vigentes de Seguridad de la Información del Ministerio de Salud, publicadas en el link https://www.minsal.cl/seguridad_de_la_informacion/ y cumplir con los





estándares de seguridad de la información establecidos por MINSAL para cada proyecto y/o tarea.²

4.1. Política General de Seguridad de la Información del Ministerio de Salud.

Toda persona que desarrolle labores para el Sector Salud, ya sea por contratación directa o indirecta, debe dar estricto cumplimiento a la Política General de Seguridad de la Información, observando sus directrices y colaborando en su aplicación e implementación desde el ámbito de sus funciones y competencias.

Los proveedores e instituciones colaboradoras de las instituciones del Sector Salud, serán responsables por los incumplimientos a las normas y políticas de seguridad de la información, con independencia del régimen contractual en base al cual desarrollen sus labores o, que su desempeño se realice a través de personal de su dependencia o subcontratación.

En caso de incumplimiento, la institución del Sector Salud se reserva el derecho de veto sobre el personal que haya cometido la infracción y podrá perseguir las responsabilidades legales, administrativas y contractuales que surjan del referido incumplimiento, sin perjuicio de solicitar al proveedor el reemplazo de los profesionales vetados por otros cuya idoneidad y competencias sean aprobados por el organismo contratante.

4.2. Políticas específicas.

El proveedor deberá dar cumplimiento a las políticas específicas de seguridad de la información en los términos que señale la entidad contratante. Especialmente deberá dar cumplimiento a las políticas de control de accesos, de desarrollo seguro de software, de seguridad física y lógica, y todas aquellas que sean requeridas de acuerdo con la naturaleza del proyecto en el cual participe.

5. GESTION DE SEGURIDAD.

Todo proveedor de las instituciones del Sector Salud, debe contar con un plan de gestión integral de seguridad, que considere auditorías internas y externas con validación de resultados y metodologías de trabajo acordes con los estándares generalmente aceptados y establecidos en las Políticas y Procedimientos vigentes de Seguridad de la Información del Ministerio de Salud y en la normativa chilena relacionada con esta materia, la cual es recopilada y puesta a disposición del público por el Gobierno de Chile, a través del sitio web de la Agencia Nacional de Ciberseguridad (ANCI)³.

² Las políticas publicadas en este sitio web, corresponden a las relacionadas directamente con los proveedores, dependiendo de la naturaleza de los proyectos o contrato, es posible que sean aplicables otras políticas, las que pueden ser solicitadas a Minsal una vez tramitado el contrato respectivo.

³ <https://anci.gob.cl/>, Normativas y decretos publicados.



Los proveedores deberán contar con un Sistema de Gestión de Incidentes que contemple, al menos, los siguientes elementos:

5.1. Gestión Ágil de Vulnerabilidades.

El proveedor deberá implementar un proceso eficiente de identificación, evaluación y mitigación de vulnerabilidades, independientemente de si han sido explotadas, notificadas por terceros o identificadas internamente. Este proceso deberá incluir:

- Monitoreo continuo de amenazas y vulnerabilidades en sus sistemas, redes y aplicaciones.
- Corrección proactiva de brechas de seguridad, siguiendo los tiempos recomendados por estándares internacionales.
- Registro y documentación de cada vulnerabilidad detectada, con trazabilidad de las acciones correctivas implementadas.

5.2. Protocolo de Comunicación de Incidentes y Vulnerabilidades.

Todo proveedor que detecte una vulnerabilidad o incidente que pueda afectar los sistemas de la institución contratante en el sector salud deberá notificarlo dentro de un plazo máximo de tres (3) horas a la jefatura designada o a la contraparte técnica correspondiente.

- La contraparte técnica institucional evaluará la criticidad del incidente y notificará de inmediato al Encargado de Seguridad de la Información de la institución.
- Los incidentes de ciberseguridad deberán ser reportados en el portal de la ANCI del Ministerio del Interior, conforme al Reglamento de Reporte de Incidentes de Ciberseguridad (Decreto N° 295/2024 de la Ley 21.663).

Los Proveedores de Servicios Esenciales deberán cumplir estrictamente con las obligaciones establecidas en el Artículo 5° de la Ley N° 21.663 y su reglamento, incluyendo la implementación de medidas de mitigación y la cooperación con la Agencia Nacional de Ciberseguridad (ANCI) en la gestión y resolución de incidente.

El informe de incidente deberá contener:

- Descripción técnica detallada de la vulnerabilidad detectada o incidente de seguridad.
- Impacto potencial o real sobre sistemas, datos e infraestructura crítica.
- Evidencia de explotación o intento de explotación de la vulnerabilidad.
- Medidas de mitigación y recuperación adoptadas o en curso, con plazos de resolución estimados.
- Revisión preventiva del sistema en caso de vulnerabilidades críticas.





Si el incidente es catalogado como crítico, se deberá activar una revisión general del sistema para identificar otras posibles vulnerabilidades explotadas, garantizando la coordinación con las autoridades y evitando comprometer investigaciones en curso.

5.3. Plan de Continuidad de Negocios y Recuperación ante Incidentes.

Los proveedores deberán contar con un Plan de Continuidad de Negocios (BCP) y un Plan de Recuperación ante Desastres (DRP) que asegure la operación ininterrumpida de los sistemas críticos de la Institución de salud contratante, la recuperación de datos ante incidentes de ciberseguridad, emergencias o desastres. Dichos planes deberán incluir:

- Gestión de respaldos con copias de seguridad periódicas en ubicaciones seguras.
- Pruebas funcionales regulares de recuperación de sistemas y datos.
- Estrategias de redundancia y alta disponibilidad para servicios esenciales.
- Planes de respuesta ante ransomware y otros ataques destructivos.
- otras medidas que se recomienden de acuerdo con los estándares generalmente aceptados.

5.4. Auditorías de Seguridad y Evaluaciones Periódicas.

Se exigirá un plan de auditoría de seguridad proactivo, con una periodicidad mínima de cada tres meses, que contemple:

- Escaneos de vulnerabilidades en infraestructuras, plataformas y aplicaciones.
- Pruebas de penetración (pentesting) en servicios críticos.
- Monitoreo de logs y análisis forense de incidentes relevantes.
- Registro y documentación de resultados, evidencias y acciones correctivas.

Los hallazgos deberán ser reportados a la contraparte institucional para fortalecer la gestión del conocimiento y promover la mejora continua en ciberseguridad. Además, la institución contratante podrá requerir los resultados de las auditorías y/o realizar revisiones independientes para evaluar y garantizar la seguridad de los servicios contratados.

5.5. Plan de Formación Continua en Seguridad de la Información.

Todos los colaboradores, proveedores y terceros que interactúen con sistemas de información del sector salud deberán recibir capacitación obligatoria en seguridad de la información, con especial énfasis en:

- Concienciación sobre ciberamenazas y prevención de riesgos.
- Buenas prácticas en manejo seguro de la información y cumplimiento normativo.
- Capacitación específica para usuarios privilegiados y administradores de sistemas.
- Simulacros de respuesta ante incidentes y campañas de phishing controladas.



5.6. Gestión de Seguridad de Recursos Humanos.

Todo el personal del proveedor o entidad colaboradora deberá cumplir con las siguientes exigencias:

- Firma de acuerdos de confidencialidad y compromiso de cumplimiento de las políticas de seguridad del Ministerio de Salud.
- Validación de antecedentes de seguridad antes de la contratación de personal con acceso a infraestructuras críticas.
- Control estricto de accesos según el principio de mínimos privilegios y segregación de funciones.

El cumplimiento de estas disposiciones será considerado un requisito esencial en los contratos o convenios, con sanciones en caso de incumplimiento.

5.7. Gestión de pruebas y aceptación de sistemas.

Los sistemas nuevos y actualizaciones se deberán someter a pruebas y verificaciones exhaustivas durante los procesos de desarrollo. Para ello se debe preparar y ejecutar un programa de actividades detallado, entradas de pruebas y los resultados esperados bajo una variedad de condiciones. Las pruebas pueden ser ejecutadas por personal de la institución contratante o por un tercero previamente seleccionado y/o aprobado por el Ministerio de Salud. A estos efectos se deben seguir los siguientes lineamientos:

5.7.1. Pruebas de seguridad de los sistemas.

Todos los productos de software desarrollados para la institución contratante deberán someterse a rigurosas pruebas y verificaciones de seguridad durante su fase de desarrollo y antes de su implementación en producción, de acuerdo con los criterios establecidos por el Minsal.

Las pruebas de seguridad se llevarán a cabo siguiendo el procedimiento definido para el análisis de seguridad en aplicaciones, garantizando que se aborden todas las vulnerabilidades y se cumplan los estándares de seguridad pertinentes.

Para reforzar aún más la seguridad y mejorar los mecanismos de protección de los productos de software destinados a la institución de salud, el proveedor debe abordar de manera efectiva las vulnerabilidades identificadas durante estas revisiones. Esto es crucial para mitigar cualquier riesgo tecnológico potencial antes de que la versión del software sea expuesta en Internet durante su implementación.

5.7.2. Ambientes y datos de prueba.





Las pruebas de sistemas se realizarán en ambientes de prueba, diferenciados de los ambientes productivos.

Asimismo, si en la fase de evaluación se requieren 'datos de prueba', deberá verificarse que se trata de datos simulados, que no correspondan a datos operacionales o datos que incluyan información calificada como crítica, confidencial o sensible.

En aquellos casos que sea indispensable utilizar datos reales en los procesos de entrenamiento y evaluación de sistemas, y la institución contratante así autorice, deberán utilizarse técnicas de anonimización o en su defecto de seudonimización, además de establecerse un sistema seguro de almacenamiento de los mecanismos y medios de reidentificación.

5.7.3. Pruebas de aseguramiento de calidad.

Con independencia de que el desarrollo o mantención se haya contratado con un proveedor, es de responsabilidad de la institución contratante del servicio garantizar la calidad del software recibido antes de que sea desplegado en un ambiente productivo.

El aseguramiento de Calidad de Software es un proceso continuo, que se debe ejecutar durante todo el ciclo de vida del sistema. En esta tarea, la institución contratante deberá cumplir con las etapas y requisitos previstos en el Procedimiento de Aseguramiento de Calidad de Software, en su versión vigente a la época que corresponda.

De todo el procedimiento se deberá constancia en actas que den cuenta de la manera que se ha resguardado tanto la correspondencia entre requerimiento formulado por la unidad responsable como los estándares de calidad, seguridad y estabilidad que se ha exigido y que deben ser cumplidos por el proveedor.

En atención a la criticidad del proceso de certificación de la calidad del software, el Ministerio podrá realizar o solicitar que se realice una validación tanto del cumplimiento del Procedimiento de Aseguramiento de Calidad de Software como de la calidad del software desplegado en un ambiente productivo, para garantizar su calidad, seguridad y la trazabilidad de los requerimientos.

5.7.4. Pruebas de aceptación de los sistemas.

Sólo podrán entrar en fase de producción los nuevos sistemas o actualización de sistemas preexistentes, que hayan superado las pruebas de aceptación definidas por el MINSAL en conjunto con el proveedor, para cada proyecto o contratación.

Para estos efectos, todo desarrollo o mantención de sistemas, debe incluir desde los términos de referencia, los criterios de aceptación previstos que satisfagan los estándares normativos y técnicos de compatibilidad con los sistemas de base, interoperabilidad y funcionalidad requerida por la unidad de negocio que lo requiera en sus procesos, además de aquellas





condiciones requeridas para garantizar la seguridad de los datos, calidad de procesos y la adherencia a las prácticas de desarrollo del sistema seguro.

En ningún caso la corrección de errores que sean de responsabilidad del proveedor podrá considerarse una mantención de cargo de la institución contratante, sino que será de cargo del proveedor ejecutarla, como condición de la aceptación del producto de que se trate. En consecuencia, las garantías que se prevean en el contrato solo tendrán vigencia desde que se haya recibido conforme la corrección respectiva.

La certificación conforme del hito correspondiente solo podrá emitirse una vez aceptado el producto de software y la documentación correspondiente.

5.8. Gestión de cambios.

Los objetivos de este proceso son:

- Minimizar los impactos sobre la disponibilidad del servicio y los riesgos operacionales.
- Responder a los requerimientos de cambios de negocio del MINSAL, para reducir incidentes, interrupciones o la reiteración de trabajos ya realizados (rework).
- Responder a los requerimientos de Negocio y de TI para que los servicios estén debidamente alineados con las necesidades de negocio de MINSAL.
- Reducir la severidad e impacto de un posible incidente asociado a un Cambio.

Existen dos clasificaciones de cambios:

- Proactivos: surgen de necesidades de Negocio o técnicas para reducir costos, mejorar la calidad de los servicios, para aumentar la efectividad o eficiencia del soporte.
- Reactivos: nacen para resolver errores o fallas, para realizar adaptaciones a requerimientos urgentes del negocio o a cambios normativos.

El proveedor realizará las actividades y tareas descritas para la entrega del Servicio de Gestión de Cambios, siendo de su responsabilidad las siguientes tareas principales:

- Participar de manera activa en la CAB (Change Advisory Board)
- Evaluar, planificar, aportar los antecedentes técnicos relevantes al cambio y aprobar o rechazar técnicamente el cambio.
- Interactuar con el *Change Coordinator*.
- Recepción, registro, seguimiento y escalamiento.
- Evaluación de impacto y riesgo en conjunto con la institución contratante.
- Categorización.
- Planificación en conjunto con la institución contratante.
- Seguimiento y revisión.
- Reportes estadísticos y de gestión del proceso (métricas).
- Proveer información de/para auditoría.





5.9. Desarrollo seguro.

- Todo proveedor que desarrolle un producto de software para Minsal, debe adoptar estándares reconocidos de desarrollo seguro, como los establecidos por el OWASP (*Open Web Application Security Project*) o el NIST (*National Institute of Standards and Technology*), y aplicar marcos de trabajo como el *Secure Software Development Lifecycle* (SSDLC). Que tienen relación con:
 - Implementar medidas para prevenir ataques de inyección de código, como *SQL Injection*, *XSS (Cross-Site Scripting)* y *CSRF (Cross-Site Request Forgery)*.
 - Las consultas a bases de datos deben utilizar procedimientos almacenados y consultas preparadas para prevenir ataques de inyección SQL.
 - En los desarrollos, debe emplear librerías y *frameworks* de terceros reconocidos por su fiabilidad y que integren mecanismos de seguridad robustos.
 - Para la exposición de los servicios API REST debe utilizar mecanismos de autenticación para su consumo privado, ya sea tokens (JWT u otros), certificados o llaves criptográficas, u otros como medios de autenticación entre puntos.
- Todo desarrollo realizado al interior del Estado debe propender a estar licenciado, acorde a las necesidades de uso con que fue creado.

5.10. Mantenimiento de Parches y actualización del *stack* tecnológico.

- El Proveedor debe mantener actualizaciones del *framework* y *stack* tecnológico exigido por MINSAL, actualizado el software subyacente y todos los componentes de la plataforma mediante la aplicación de parches de seguridad y actualizaciones críticas, garantizando la protección y la integridad del sistema a lo largo del tiempo, haciéndose cargo del impacto que tenga el incumplimiento de esta obligación en la operación del servicio.
- El proveedor es responsable de notificar con antelación a la institución contratante sobre cualquier mantenimiento programado que pueda afectar la disponibilidad del servicio. Tratándose de mantenimiento no programado debido a vulnerabilidades críticas, el Proveedor cumplirá con este deber de información tan pronto como sea posible.
- El proveedor deberá garantizar que todos los servidores web, de bases de datos y de aplicaciones estén configurados de acuerdo con las mejores prácticas de seguridad. Se deberá realizar un proceso de *hardening* para reducir la superficie de ataque.

6. PROPIEDAD INTELECTUAL.

- **Titularidad y Derechos de Propiedad Intelectual:** Toda creación intelectual, incluyendo, pero no limitada a software, bases de datos, código fuente, documentación, algoritmos, diseños, metodologías y otros elementos relacionados con el desarrollo de sistemas, será de propiedad exclusiva de la institución contratante, con independencia del régimen contractual de las personas que hayan participado de su elaboración, salvo que el contrato





señale expresamente una condición diferente. Sin perjuicio de ello, la institución podrá reconocer a los creadores los derechos morales, si corresponde.

- **Propiedad del Código Fuente:** Todo código fuente generado en el marco de las actividades de desarrollo de sistemas, ya sea en proyectos internos o externos y sin importar el entorno en que se aloje (local o en la nube), será de propiedad exclusiva de la institución contratante. Este código deberá ser documentado, versionado y almacenado en un repositorio centralizado y seguro de la organización, bajo control y acceso restringido. La propiedad del código fuente garantiza al contratante, el derecho de uso, modificación, distribución y explotación de los sistemas desarrollados sin limitaciones.
- **Contratación de Terceros:** Cuando el desarrollo de sistemas sea realizado total o parcialmente por proveedores externos o consultores, el contrato deberá incluir una cláusula de cesión de derechos, mediante la cual se transfiera la totalidad de la propiedad intelectual de las creaciones resultantes a nombre del contratante. Además, estos contratos deberán disponer las medidas que permitan asegurar que el código fuente y la documentación técnica completa sean entregados al Minsal, garantizando así la disponibilidad y el control total sobre los activos desarrollados.
- **Licencias y Uso de Herramientas de Terceros:** En caso de que el desarrollo requiera el uso de software o componentes de terceros, ya sean de código abierto o bajo licencia comercial, se deberán revisar y aprobar las condiciones de uso para asegurar que no afecten los derechos de propiedad intelectual del Minsal sobre el producto final. Solo se podrán utilizar componentes cuya licencia permita su integración sin comprometer la titularidad o explotación de la creación intelectual de la organización.
- **Confidencialidad y Protección de Información:** Toda información, especificación técnica, metodología o código generado durante el desarrollo de sistemas será considerado confidencial y propiedad de la contratante. Está estrictamente prohibida la divulgación, copia o uso no autorizado por parte del proveedor o sus dependientes, de la información revelada con ocasión del contrato.
- **Convenio de confidencialidad con personas naturales:** Tratándose de la participación de personas naturales en el análisis o desarrollo de sistemas, ya sea como empleado de un proveedor, personal a honorarios, estudiantes en práctica, convenio de colaboración, etc., se deberá firmar acuerdos de confidencialidad (NDAs) para asegurar la protección de la información.
- **Derechos de uso en caso de terminación de contratos:** En situaciones en las que se dé por terminado el contrato con un proveedor de desarrollo, la entidad contratante mantendrá el derecho exclusivo de uso y acceso a todos los materiales, código fuente y documentación producidos en el marco del contrato. El proveedor deberá realizar la transferencia inmediata de todos los derechos y activos digitales a Minsal, asegurando la titularidad total y sin limitaciones de uso, salvo que exista pacto en contrario.
- **Propiedad de los modelos de datos y condiciones de funcionamiento de SaaS:** Tratándose de soluciones provistas a la entidad contratante en la modalidad Software





como Servicio, se entenderá que el proveedor es titular de los activos creados por la empresa, tales como el código fuente y el software ejecutable, y documentación de software. Sin perjuicio de lo anterior, el contratante será propietario del modelo de datos y diseño de procesos que haya facilitado al proveedor con ocasión de las adaptaciones requeridas para la satisfacción de las necesidades institucionales. Todo contrato de SaaS debe incluir la condición de la entrega de los documentos creados en conjunto con el proveedor para la arquitectura y el diseño del servicio.

7. ALOJAMIENTO DE DATOS EN SERVIDORES Y USO DE CLOUD COMPUTING.

Los contratos que consideren servicios en la nube deberán cumplir con los lineamientos previstos en la resolución exenta N° 619 - B de 26 de noviembre de 2018, de la Dirección de Compras y Contratación Pública, que aprueba la directiva de contratación pública N° 32, "Recomendaciones para la contratación de servicios en la nube". Sin perjuicio de lo anterior y en particular, deberán cumplir las siguientes condiciones y requisitos:

- Los sistemas de acceso remoto a datos deberán ser diseñados de forma tal que sólo puedan ser accedidos desde dentro de la Red de comunicaciones de la institución contratante, con canales de comunicación seguros y debidamente protegidos con nombre de usuario y contraseña segura o con autenticación a través de Clave Única.
- De todo proceso que se lleve a cabo sobre el sistema o los datos, debe quedar registros detallados y auditable que contengan al menos la identificación del usuario que accede a los datos (requiriente), la descripción del contenido al que accede, el motivo o propósito del acceso, operaciones de tratamiento realizadas y destinatarios de la información.
- Los sistemas deberán considerar la ejecución de respaldos que permitan la recuperación segura de la información en tiempos razonables para procesos críticos de información, desde la óptica de continuidad de servicios.
- Los datos sensibles deberán ser seudonimizados antes de ser ingresados en sistemas "en nube", debiendo mantenerse en los servidores locales los datos de re-identificación, en archivos debidamente protegidos.



Consecuentemente, respecto de la contratación de servicios de esta naturaleza se deberán adoptar los siguientes resguardos:

7.1. Medidas organizativas.

7.1.1. Prohibición de uso de la información más allá de las necesidades asociadas al cumplimiento y finalidad del contrato.

- Toda persona que entre contacto con la información que constan en los sistemas de la Institución contratante tiene la calidad de mero procesador o mandatario y por ende meros tenedores de la información, pudiendo utilizarla sólo en cumplimiento de las obligaciones que emanen de los contratos o acuerdos de que se trate, quedándole proscrito su uso para fines distintos de aquellos que hayan sido expresamente autorizados por la entidad contratante.

7.1.2. Acceso restringido.

- Queda prohibido utilizar servicios de almacenamiento en la nube o cualquier servicio de nube pública que no haya sido previamente autorizado por el área de TI o el comité de ciberseguridad correspondiente.

7.1.3. Auditorías externas de seguridad y que entregue las evidencias correspondientes.

- Todos los servicios en la nube contratados deben garantizar la capacidad de auditar actividades realizadas, incluyendo:
 - Accesos, modificaciones y eliminaciones de datos.
 - Movimientos entre regiones de almacenamiento.
 - Los registros de auditoría deben mantenerse disponibles por un período mínimo de 5 años y ser accesibles para inspecciones internas o regulatorias.
- Herramientas de Auditoría.
 - Se deben implementar herramientas automáticas para supervisar las actividades en la nube y generar reportes periódicos sobre el uso del servicio.

7.1.4. Notificación de incidentes de seguridad de la información o ciberseguridad.

- Los proveedores de servicios en la nube están obligados a:
 - Notificar al Oficial de Seguridad de la Información de la institución contratante sobre cualquier incidente de seguridad que afecte la confidencialidad, integridad o disponibilidad de los datos en un plazo máximo de 3 horas.





- Resguardar evidencias iniciando cadena de custodia.
- Proveer detalles del incidente, las medidas adoptadas y los planes de mitigación.
- Los funcionarios deben reportar inmediatamente cualquier anomalía o incidente relacionado con los servicios en la nube al equipo de TI o al CISO (*Chief Information Security Officer*) del Minsal.
- Los incidentes deberán reportarse en el portal de la Agencia Nacional de Ciberseguridad (ANCI), conforme al Reglamento de Reporte de Incidentes de Ciberseguridad (Decreto N° 295/2024).
- Los Proveedores de Servicios Esenciales deberán cumplir estrictamente con las obligaciones establecidas en el Artículo 5° de la Ley N° 21.663 y su reglamento, incluyendo la implementación de medidas de mitigación y la cooperación con la ANCI en la gestión y resolución de incidente.

7.1.5. Monitoreo y Cumplimiento.

- Para una correcta operación de cualquier servicio tecnológico, es fundamental contar monitoreo de los servicios prestados y el cumplimiento de los niveles de servicio previstos.
- Se deberán implementar herramientas automáticas para supervisar las actividades en la nube y generar reportes periódicos sobre el uso del servicio.
- Condiciones contractuales: Se deberá definir claramente en los contratos, el alcance de los servicios prestados y los márgenes de crecimiento o reducción elástica del mismo.
- Acuerdos de Nivel de Servicio (SLA) y las sanciones en caso de incumplimiento, debiendo preverse expresamente la diferenciación entre tiempo de respuesta y tiempo de resolución. Garantizar una disponibilidad mínima del 99.98% del servicio y soporte técnico 24/7.

7.1.6. Medidas frente a incumplimientos contractuales.

- En caso de incumplimiento de los SLA, los contratos deben incluir cláusulas que permitan perseguir la responsabilidad del proveedor, tales como:
 - Penalidades económicas proporcionales al impacto del incumplimiento.
 - Rescisión anticipada del contrato frente a incumplimientos graves, sin costos adicionales para el contratante.
 - Compromisos de Mitigación: Si se produce un incidente o falla, el proveedor debe implementar de inmediato un plan de acción correctiva para mitigar los daños y prevenir futuras ocurrencias.
 - Mantenimiento normativo, para el caso en que, durante la ejecución del proyecto exista una reforma normativa que impacte en el diseño, desarrollo o implementación del sistema.



- Devolución y Eliminación de Datos, se deberán establecer condiciones claras para la devolución y eliminación segura de los datos al término del contrato, garantizando que no queden copias residuales en los sistemas del proveedor.

7.1.7. Resguardos de legalidad de las cláusulas.

Los contratos no deberán considerar cláusulas que estén fuera de las competencias del Ministerio, a saber:

- En materia de resolución de controversias: Prórroga de competencia a tribunales extranjeros o cláusulas de arbitraje ante árbitros arbitradores.
- Respecto de la responsabilidad: Renuncia a las responsabilidades del proveedor, sus *partners* o dependientes.
- En materia de garantías: Renuncia a las garantías; establecimiento de condiciones de vigencia de la garantía respecto de entregas parciales que extingan o limiten la garantía del producto final.
- Cesiones de datos: Aceptación de cláusulas que representen cesiones de datos sensibles o datos personales en hipótesis no autorizadas por la ley.

7.1.8. Propiedad Intelectual en Entornos Cloud.

Todas las actividades realizadas en la nube pública deberán cumplir con las leyes y normativas aplicables sobre propiedad intelectual y propiedad industrial, incluyendo las relacionadas con patentes, derechos de autor, marcas y secretos comerciales, debiendo adoptarse a lo menos las siguientes medidas:

- Toda la propiedad intelectual generada, creada o desarrollada durante la ejecución de actividades en entornos de nube pública será propiedad exclusiva del Minsal. Esto incluye, pero no se limita a, software, código fuente, algoritmos, documentos, diseños, bases de datos, y cualquier otro material o activo que derive de las actividades realizadas en estos entornos.
- El acceso a las obras protegidas por propiedad intelectual será restringido a las personas autorizadas y se revisará periódicamente los derechos de usuarios y privilegios para garantizar que solo los empleados y colaboradores necesarios tengan acceso a los recursos relevantes.
- Minsal implementará las medidas de seguridad necesarias para proteger el material protegido por propiedad intelectual en los entornos de nube pública, incluyendo el uso de encriptación, controles de acceso y autenticación, y monitoreo continuo.
- En la relación con proveedores, se adoptarán a lo menos los siguientes resguardos:
 - Los proveedores de servicios en la nube pública (incluidos los servicios de almacenamiento, procesamiento y desarrollo) no obtendrán derechos sobre las



obras protegidas por propiedad intelectual de Minsal ni sobre los datos que en ellas consten, si corresponde, en virtud de la utilización de dichos servicios.

- Los proveedores solo tendrán derecho a usar el material protegido bajo las condiciones específicas acordadas en los contratos de servicio, y únicamente en la medida necesaria para la prestación de sus servicios.

7.2. Medidas técnicas.

El proveedor debe implementar medidas técnicas robustas para garantizar la seguridad y disponibilidad de los servicios contratados en la nube, alineándose con los estándares internacionales y mejores prácticas. Las medidas incluyen al menos certificaciones de seguridad, protección de datos mediante encriptación y seudonimización, y la elasticidad de los recursos tecnológicos.

7.2.1. Certificaciones de seguridad: Los proveedores de servicios en la nube contratados deben estar certificados bajo estándares internacionales reconocidos, como:

- ISO/IEC 27001: Gestión de la seguridad de la información.
- ISO/IEC 27017: Controles de seguridad específicos para servicios en la nube.
- ISO/IEC 27018: Protección de datos personales en servicios en la nube.

Además, los servicios contratados deben cumplir con las regulaciones nacionales, como la Ley de Protección de Datos Personales, Ley marco de Ciberseguridad, Ley de Delitos Informáticos, asegurando que la información almacenada sea tratada conforme a las disposiciones legales chilenas.

7.2.2. Encriptación de datos: Tratándose de datos confidenciales y sensibles deberán aplicarse técnicas de encriptación que permitan asegurar que no serán accedidos ilegítimamente.

7.2.3. Seudonimización.

- En caso de información sensible de personas naturales (datos personales sensibles) se recomienda aplicar técnicas de seudonimización, manteniendo en el servidor local los códigos que permitan la reidentificación de los datos. Esto para evitar que la localización de datos en países en que existan normas de desenscriptación forzosa para las autoridades no judiciales ponga en riesgo el deber de secreto que rige de acuerdo con la ley 19.628 y el artículo 19 números 1 y 4 de la Constitución Política de la República.
- Técnicas de Seudonimización: Para asegurar la confidencialidad de información altamente sensible (como los datos de salud) o información confidencial, es recomendable el uso de técnicas de tokenización y enmascaramiento. Estas técnicas sustituyen los datos reales por identificadores o versiones enmascaradas, que no tienen valor fuera del sistema autorizado.





- La técnica elegida debe ser aplicada antes de almacenar datos personales sensibles y garantizar que las claves utilizadas para la seudonimización se gestionen en sistemas separados y seguros.

7.2.4. **Elasticidad:** Se debe tener especial consideración en una planificación adecuada de la capacidad que permita reservar capacidad con anticipación o definir en el contrato valores de crecimiento flexibles, que no obliguen a realizar un nuevo proceso de compra.

- Los servicios en la nube deben ofrecer elasticidad, permitiendo aumentar o reducir automáticamente los recursos según las necesidades del MINSAL.
- En los presupuestos se debe prever la elasticidad como condición de provisión del servicio, contemplando márgenes coherentes con la posibilidad de cubrir imprevistos.

7.2.5. **Garantía de Disponibilidad:** Se deben configurar sistemas para operar bajo esquemas de alta disponibilidad (HA), distribuyendo recursos en múltiples regiones o zonas de disponibilidad y definir mecanismos para la rápida restauración de operaciones en caso de incidentes mayores como fallos críticos, ataques cibernéticos o desastres naturales a través de estándares y protocolos de recuperación ante desastres (BCP/DRP).

7.2.6. **Geolocalización y Protección de Datos Sensibles.**

- La recopilación y uso de datos de geolocalización debe limitarse a lo estrictamente necesario para satisfacer las necesidades de información requeridas para el ejercicio de las competencias legales del organismo.
- Si los datos de geolocalización se almacenan o procesan fuera de Chile, la Institución contratante deberá garantizar que los proveedores de servicios en la nube cumplan con estándares aceptables de protección de datos personales. Esto incluye elegir proveedores ubicados en países con protección de datos equivalente o establecer contratos específicos que aseguren la integridad, confidencialidad y seguridad de los datos transferidos.
- Implementar medidas de seguridad para proteger los datos de geolocalización, incluyendo el cifrado en tránsito y en reposo, así como el uso de controles de acceso restringido.
- Los titulares de los datos de geolocalización tienen derecho a ejercer el derecho de acceso a los datos de geolocalización que les conciernen y que consten en los sistemas de responsabilidad de la Institución contratante. Sin embargo, la procedencia de los derechos de rectificación, supresión o cancelación deberá evaluarse caso a caso, pudiendo denegarse el ejercicio de estos derechos que impida o entorpezca el cumplimiento de las labores del organismo.
- La Institución contratante deberá proporcionar procedimientos para que los titulares puedan ejercer estos derechos de manera efectiva, debiendo preverse en el contrato las labores de asistencia del proveedor en aquellas materias en que se requiera, para los efectos de cumplir los plazos previstos en la legislación de protección de datos personales.





- MINSAL debe llevar un registro detallado de todos los tratamientos, accesos y modificaciones de los datos de geolocalización, con el fin de asegurar la trazabilidad y verificar el cumplimiento de las normativas de protección de datos de Chile.
- MINSAL debe realizar auditorías periódicas para verificar el cumplimiento de estas medidas, garantizando que solo el personal autorizado tenga acceso a los datos de geolocalización.

7.2.7. Automatización de respaldos y pruebas de restauración.

- Todos los sistemas críticos deben contar con copias de seguridad automatizadas en la nube para garantizar su disponibilidad en caso de fallas o desastres. Además de realizar pruebas regulares para verificar que los datos respaldados puedan restaurarse con éxito.

7.2.8. Distribución de copias.

- Las copias de seguridad deben almacenarse en múltiples regiones para proteger contra desastres regionales.
- Las copias de seguridad deben ser almacenadas exclusivamente en nubes públicas con infraestructura accesible fácilmente a través de medios seguros desde el territorio de Chile, con el fin de asegurar la resiliencia y la continuidad del servicio ante cualquier desastre o incidente que limite la conectividad internacional, y para garantizar el cumplimiento de las leyes sobre protección de datos y ciberseguridad aplicables en el país.
- En caso de que el proveedor de la nube pública cuente con infraestructura en Chile y fuera del país, se deberá implementar una política de no replicación fuera de Chile o, al menos, controlar estrictamente la replicación de datos hacia centros de datos ubicados en otros países.
- Se recomienda implementar un enfoque híbrido para el almacenamiento de copias de seguridad, donde la copia primaria se almacene en infraestructura propia (ya sea local o en un servicio de nube privada) y la copia secundaria en nube pública. Este enfoque asegura redundancia y proporciona un control robusto sobre la información crítica para el Minsal, garantizando la disponibilidad y seguridad de los datos en todo momento.

7.2.9. Monitoreo y Registro de Eventos:

- El proveedor debe garantizar que se disponga de los registros detallados de auditoría (logs) en todas las capas del sistema, incluyendo:
 - Implementar herramientas automatizadas de gestión de parches que permitan detectar, priorizar y aplicar actualizaciones de seguridad eficientemente.
 - Configurar alertas proactivas para abordar de manera inmediata las vulnerabilidades no gestionadas o críticas.





- Los sistemas de monitoreo proactivo permiten identificar amenazas en sus etapas iniciales y activar respuestas automáticas que reduzcan el impacto de posibles incidentes.
- Registros de autenticación y acceso (fallidos y exitosos) en sistemas críticos y plataformas *cloud*.
- Eventos de red y tráfico sospechoso, identificando accesos desde direcciones IP no autorizadas o patrones anómalos de conexión.
- Modificaciones en configuraciones y permisos a nivel de infraestructura, aplicaciones y bases de datos.
- Accesos y manipulaciones de datos sensibles, en conformidad con el principio de minimización de datos.

7.2.10. Protección contra Amenazas:

- El proveedor debe implementar una arquitectura de seguridad en capas para la protección de los servicios *cloud*, asegurando la detección, prevención y respuesta ante amenazas avanzadas. Considerando los siguientes controles mínimos:
 - *Web Application Firewall* (WAF).
 - Protección contra ataques DDoS.
 - Segmentación de Red y Zero Trust.
 - *Threat Intelligence* y Análisis de Indicadores de Compromiso (IoCs).

7.3. Seguridad en Nube.

Los usuarios de servicios en nube necesitan garantías de que los riesgos asociados al almacenamiento de sus datos y ejecución de sus aplicaciones en estos ambientes son comprendidos y gestionados adecuadamente. Al ser responsabilidad del Prestador de Servicios la implementación de algunas de las medidas de seguridad, se deberá prestar particular atención a que los criterios de seguridad utilizados por el mismo sean reconocidos, transparentes y verificables.

Esto puede incluir auditorías o certificaciones externas que cumplan con estas características. Algunos principios de seguridad que los Prestadores de Servicios deben cumplir son:

- **Controles de acceso, identidad y autenticación robustos tanto en tránsito como en reposo:** El acceso a todas las interfaces de servicio deberán restringirse a personas autenticadas y autorizadas para prevenir cambios no autorizados en el servicio del consumidor, robo o modificación de datos o la denegación de servicio.
- **Protección de los activos de información y datos, tanto en tránsito como en reposo:** Los centros de datos deben estar contruidos bajo estándares reconocidos de seguridad, para que los datos, activos y redes estén adecuadamente protegidos contra la manipulación, espionaje, pérdida, daño o incautación. Deben existir criterios claros sobre el uso de controles criptográficos sobre los datos. Asimismo, debe existir una política clara de



respaldo y retención de datos, y plazos específicos para su posterior eliminación. Es importante que la propiedad de un dato no sea modificada al ser tratada en entornos *cloud*.

- **Seguridad Operacional, del Personal y Proveedores:** El Prestador de Servicios debe tener procesos y procedimientos establecidos para garantizar la seguridad en la operación del servicio, incluyendo la gestión de su personal y proveedores, que considere la posibilidad de vetar personal o proveedores que tengan historiales de incumplimiento normativo o contractual en el ámbito de seguridad de la información.
- **Gestión segura de los clientes, incluyendo separación de estos y promoción del uso seguro del servicio:** El proveedor deberá promover el uso seguro de sus servicios en la nube, delimitando de forma clara las responsabilidades de cada parte. Adicionalmente. El proveedor deberá adoptar las medidas adecuadas para garantizar la separación lógica o física de sus distintos clientes, según sea necesario.
- **Proveer información de auditorías a los clientes:** El proveedor deberá proporcionar a la institución contratante, toda la información que le permita controlar el acceso a sus servicios. Especialmente deberá llevar registros de auditoría de accesos, sesiones y datos contenidos en los sistemas, sin perjuicio de la atribución de la institución de realizar las comprobaciones que le permitan verificar el correcto cumplimiento de los contratos o acuerdos de servicio, ya sea a través de capacidades propias o de certificaciones y auditorías de terceros. Este acceso debe ser razonable y respetando las políticas de confidencialidad.
- **Marco de gobernanza:** El proveedor deberá tener un marco de gobernanza de seguridad que entregue suficiente coordinación y dirija su enfoque en la gestión del servicio y la información que éste contiene.
- **Reporte de incidentes de seguridad:** El proveedor debe transparentar a la contraparte institucional información detallada y oportuna sobre los incidentes de seguridad que afecten el servicio contratado o a la información de éste y adoptar medidas para mitigar los posibles daños resultantes.

8. OBLIGACIONES DE SEGURIDAD PARA SOLUCIONES DE SOFTWARE COMO SERVICIO (SAAS).

Dado que el presente instructivo aborda aspectos críticos de seguridad de la información, gestión de datos y operación tecnológica, todos los proveedores de soluciones Software como Servicio (SaaS) deben cumplir estrictamente con los puntos mencionados en este documento y con especial atención en los siguientes requisitos:

8.1. Cumplimiento Normativo y Regulatorio.

El proveedor debe garantizar el cumplimiento exhaustivo de las siguientes normativas y políticas vigentes, demostrando su aplicabilidad específica a la solución SaaS ofrecida:



- Ley N° 19.628 sobre Protección de la Vida Privada: Implementación de medidas técnicas y organizativas robustas para asegurar la confidencialidad, integridad y disponibilidad de los datos personales, incluyendo el consentimiento informado, derechos de los titulares y la notificación de brechas de seguridad conforme a la ley.
- Ley N° 21.663 sobre Ciberseguridad: Adopción de un marco de ciberseguridad integral que abarque la identificación, protección, detección, respuesta y recuperación ante incidentes de seguridad, alineado con los estándares y mejores prácticas definidos por la ley y sus regulaciones complementarias.
- Política de Seguridad de la Información del Sector Salud y sus procedimientos complementarios: Cumplimiento estricto de los lineamientos, estándares y procedimientos establecidos en la Política de Seguridad de la Información y Ciberseguridad del Minsal, incluyendo la adopción de controles de seguridad definidos en sus políticas secundarias y documentos relacionados.

8.2. Resguardo de Datos, Soberanía y Continuidad Operacional.

- La infraestructura tecnológica para el alojamiento de datos debe cumplir rigurosamente con los criterios definidos en el punto 7 (Alojamiento de Datos en Servidores y Uso de Cloud Computing). Se priorizarán servicios con infraestructura accesible fácilmente a través de medios seguros desde el territorio de Chile o en jurisdicciones con marcos regulatorios de protección de datos equivalentes al chileno.
- La implementación de controles técnicos y organizativos robustos para garantizar la protección integral de la información en todas sus etapas (recopilación, procesamiento, almacenamiento, transmisión y eliminación). Esto incluye la aplicación de principios de confidencialidad (acceso restringido y basado en roles), integridad (prevención de alteraciones no autorizadas) y disponibilidad (acceso autorizado y oportuno a los datos).
- Implementación de una estrategia integral de respaldo de datos que incluya copias de seguridad periódicas, seguras (cifradas y almacenadas en ubicaciones separadas), verificables y con retenciones definidas según las políticas y normativas aplicables.

8.3. Controles Técnicos de Seguridad Avanzados.

- Deberán incorporarse herramientas y servicios de seguridad activos (ver punto 9. Herramientas de Seguridad) como detección de amenazas, monitoreo continuo y mecanismos de control de acceso con privilegios mínimos.
- Integración e implementación efectiva de controles técnicos que incluyan:
 - Autenticación Multifactor (MFA): Obligatoria para todos los accesos a la solución SaaS, tanto para usuarios finales como para administradores, utilizando al menos dos factores de autenticación diferentes.
 - Mecanismos de Gestión de Credenciales, que incluyan:



INSTRUCTIVO SOBRE CLÁUSULAS DE PROTECCIÓN DE DATOS Y SEGURIDAD DE LA INFORMACIÓN DEL SECTOR SALUD



Sistema de Gestión de Seguridad de la Información - Minsal

MINISTERIO DE SALUD

ITS-NC- 006

Versión: 5

Página 26 de 46

TLP:BLANCO

- Protección contra automatización maliciosa: Incorporación de Captcha o ReCaptcha en formularios de inicio de sesión y recuperación de contraseñas para mitigar ataques automatizados.
- Control de intentos de acceso: Restricción del número de intentos fallidos antes de aplicar medidas de mitigación.
- Bloqueo por intentos fallidos: Definición de un período de bloqueo temporal para usuarios que superen el límite de intentos fallidos.
- Gestión de sesiones: Implementación de un tiempo de expiración para sesiones inactivas con cierre automático.
- Requisitos de contraseñas:
 - Uso de contraseñas robustas con una longitud mínima de 8 a 12 caracteres.
 - Aplicación de listas de contraseñas prohibidas para prevenir el uso de credenciales vulnerables.
 - Almacenamiento del historial de las últimas cinco contraseñas utilizadas por cada usuario y restricción de su reutilización.
- Restablecimiento seguro de contraseña:
 - Generación de enlaces de restablecimiento de un solo uso, con tiempo de expiración y validación del usuario.
 - Aplicación de una validación adicional antes de permitir el restablecimiento, incluyendo la autenticación multifactor (2FA).
- **Cifrado Robusto:** Implementación de algoritmos de cifrado estándar de la industria (AES-256 o superior) para la protección de datos en tránsito (TLS/SSL) con el uso de certificados digitales válidos y emitidos por autoridades certificadoras confiables y en reposo (a nivel de base de datos, almacenamiento de archivos, etc.).
- **Detección y Prevención de Amenazas:** Implementación de sistemas de detección y prevención de intrusiones (IDS/IPS), firewalls de última generación (NGFW), soluciones anti-malware avanzadas y análisis de comportamiento anómalo, WAF (Web Application Firewall) para la detección y prevención de Amenazas de aplicaciones web.
- **Monitoreo Continuo y Alertas:** Implementación de un sistema de monitoreo de seguridad 24/7 que registre eventos relevantes, genere alertas en tiempo real ante incidentes o comportamientos sospechosos, y permita el análisis forense.
- **Control de Acceso Basado en Roles (RBAC) y Privilegio Mínimo:** Implementación de un modelo de control de acceso granular basado en roles y responsabilidades, asegurando que los usuarios solo tengan los permisos necesarios para realizar sus funciones. Los servicios deben contar con soluciones de gestión de identidades que permitan la validación unívoca de pacientes, proveedores y establecimientos, minimizando errores o duplicidades, y asegurando la correcta administración de las identidades.





- **Alta Disponibilidad y Tolerancia a Fallos.**

- Garantizar la alta disponibilidad de los sistemas críticos (99,98%), con arquitecturas resilientes y mecanismos de redundancia que aseguren la continuidad operativa frente a fallos o interrupciones.
- Implementar una arquitectura de alta disponibilidad, con balanceo de carga y redundancia, asegurando tolerancia a fallos y respaldo periódico de datos clínicos.

- **Protección contra Vulnerabilidades y Actualizaciones.**

- Los servicios deben estar diseñados para recibir actualizaciones y parches de seguridad regulares, protegiendo la infraestructura contra vulnerabilidades conocidas y garantizando la mitigación de riesgos emergentes.
- Mantener actualizado el software subyacente y todos los componentes de las plataformas mediante la aplicación regular de parches de seguridad y actualizaciones críticas.
- Notificar al Minsal con antelación sobre cualquier mantenimiento programado que pueda afectar la disponibilidad del servicio.
- En situaciones de mantenimiento no programado debido a vulnerabilidades críticas, deberá informar al Minsal tan pronto como sea posible.
- El proveedor asume la responsabilidad total por la aplicación adecuada y oportuna de parches de seguridad, así como por la gestión efectiva de cualquier impacto en la operación del servicio.

- **Respuesta a Incidentes.**

- Se debe establecer un plan de respuesta a incidentes que detallará los procedimientos a seguir en caso de detectarse una violación de seguridad, incluyendo la investigación inmediatamente desde su detección y la notificación oportuna dentro de las primeras 3 horas luego de detectado, a las partes afectadas y las autoridades competentes según la normativa vigente. Asimismo, se deberá entregar un informe preliminar de evaluación de este incidente dentro de las primeras 72 horas de su detección y un informe detallado de las causas y medidas de mitigación y control aplicadas a los 15 días corridos.
- Cuando la contraparte del contrato tome conocimiento de un incidente crítico o alto, deberá informar inmediatamente al Encargado de Seguridad del MINSAL, quien deberá calificar su criticidad y notificar a través del portal de la ANCI del Ministerio del Interior, de acuerdo con los criterios establecidos en el reglamento de reporte de Incidentes de Ciberseguridad (Decreto N°295). Sin perjuicio de la exigencia de la Ley sobre los Proveedores de Servicio Esencial quienes deberán dar cumplimiento a lo dispuesto en el Artículo 5° de la Ley 21.663 y su reglamento.





- **Revisiones y Auditorías de Seguridad.**

- Minsal podrá llevar a cabo auditorías periódicas de seguridad realizadas por sí o terceros independientes para evaluar la efectividad de las medidas de seguridad implementadas y garantizar el cumplimiento de los estándares de seguridad establecidos.

- **Recuperación ante Desastres (DRP).**

- Para la infraestructura tecnológica que se provea para facilitar el intercambio de información de salud, se debe desarrollar, implementar y mantener un Plan de Recuperación ante Desastres (DRP) integral y eficaz para garantizar la continuidad del servicio, el que deberá ser entregado a la contraparte técnica del Minsal, así como las evidencias de pruebas regulares y ejercicios de recuperación que evalúen la eficacia del DRP.

- **Respaldo y Recuperación.**

- Se deberá contar con un sistema de respaldos regulares de los datos almacenados en la plataforma, con una frecuencia acorde a la frecuencia especificada en las Políticas del Ministerio y llevar a cabo pruebas regulares de los procedimientos de restauración de respaldos para verificar su integridad y efectividad.
- En caso de pérdida o corrupción de datos se deberá restaurar la integridad de estos datos en un plazo de máximo de 2 horas tras la detección del incidente.

- **Monitoreo y Auditoría.**

- La infraestructura debe incluir sistemas de monitorización continua (SIEM) y auditoría detallada, permitiendo la trazabilidad de todas las transacciones y actividades, y asegurando la detección de incidentes de seguridad de manera oportuna.
- Todos los servicios provistos deben ser monitoreados las 24 horas los 7 días de la semana.
- Realizar análisis regular de los registros de actividad (logs) para identificar posibles brechas de seguridad o anomalías en el comportamiento del sistema.
- Implementar sistemas de detección de intrusos para identificar intentos de acceso no autorizado o actividades sospechosas en tiempo real.

- **Supresión, cancelación o destrucción de datos.**

- El proveedor deberá asegurar mecanismos que permitan la supresión o destrucción definitiva de los datos almacenados en la plataforma, cuando estos ya no sean necesarios para los fines del tratamiento.
- La eliminación de datos deberá realizarse de manera segura, irreversible y verificable, aplicando procedimientos que garanticen la imposibilidad de recuperación posterior.





- En caso de cancelación de servicios, terminación de contrato o solicitud expresa de la contraparte técnica del MINSAL, el proveedor deberá proceder a la eliminación total de los datos dentro de un plazo máximo de 15 días corridos, debiendo entregar a la contraparte un certificado de destrucción segura, validado por mecanismos de auditoría.
- Esta supresión deberá incluir datos en ambientes de producción, respaldo, contingencia, desarrollo o prueba.
- Cuando los datos deban conservarse por mandato legal, el proveedor deberá garantizar su preservación segura, con acceso restringido y trazabilidad completa hasta su destrucción final.

- **Gestión de Configuraciones Seguras.**

- Se deberá proporcionar documentación completa que detalle la arquitectura de seguridad, las configuraciones implementadas y los procedimientos de seguridad.
- El proveedor debe establecer y mantener configuraciones seguras (hardening) para todos los componentes del servicio, con respaldo de documentación respectiva.
- Estas configuraciones deben ser auditables y no modificables sin notificación previa al Minsal.

- **Seguridad en APIs**

- Todas las APIs utilizadas o expuestas por el servicio SaaS contratado por Minsal, deberán implementarse bajo principios de seguridad por diseño, empleando autenticación robusta (como OAuth 2.0), autorización granular, cifrado TLS 1.3, y protección contra amenazas comunes (OWASP API Top 10). Se exigirá validación de entradas, limitación de tasas de consumo, trazabilidad completa de accesos y documentación actualizada.

8.4. Gestión Segura de Datos Productivos en Entornos No Productivos.

- El uso de datos reales en entornos distintos al productivos deberá cumplir con las disposiciones del punto 11 sobre la Gestión de Datos Productivos y sólo se podrá hacerse con autorización expresa del organismo contratante.

8.5. Interoperabilidad, Adherencia a la Arquitectura Referencial y Uso de IA.

- La solución SaaS debe demostrar una clara alineación con los lineamientos definidos en los puntos 12 (Arquitectura Referencial) y 13 (Interoperabilidad), facilitando la integración segura y eficiente con otras plataformas y sistemas del ecosistema digital de salud. Esto implica la adopción de estándares de interoperabilidad (ej., HL7, FHIR), estándares de





integración aceptados (como REST, GraphQL, JSON, XML) protocolos de comunicación seguros (ej., HTTPS con TLS), y formatos de datos comunes.

- El proveedor deberá especificar los mecanismos de integración que ofrece la solución SaaS, detallando los protocolos, APIs y estándares utilizados, así como las medidas de seguridad implementadas para proteger la información durante la transferencia e intercambio con otros sistemas.
- En caso de incluir componentes de IA, el proveedor deberá declarar su uso conforme al punto 14. Uso de Inteligencia Artificial (IA), cumpliendo con principios de transparencia, trazabilidad y explicabilidad, especialmente cuando intervenga en procesos clínicos o de toma de decisiones.

8.6. Entrega Segura de Información y Eliminación al Término del Contrato.

- Al finalizar la relación contractual, el proveedor deberá entregar al organismo contratante toda la información y configuraciones de la plataforma de manera completa, organizada y en formatos interoperables, según lo especificado en el punto 15 (Entrega de Sistemas y Datos al Término del Contrato). Esto incluye la documentación técnica, las bases de datos, el código fuente (si aplica) y cualquier otro elemento necesario para la continuidad operativa.
- El proveedor deberá garantizar la eliminación segura e irreversible de todos los datos del organismo contratante que se encuentren en su posesión o bajo su control, utilizando métodos que impidan la recuperación de la información (ej., borrado seguro, destrucción física de medios). Se deberá proporcionar evidencia documentada de este proceso.

9. HERRAMIENTAS DE SEGURIDAD.

Sin perjuicio de las herramientas y medidas de seguridad especiales aplicables a las tecnologías empleadas o modalidad contractual, en todo proceso de adquisición de soluciones tecnológicas, se exigirá que las herramientas contratadas aborden de manera integral tanto la seguridad en la capa de telecomunicaciones, como la de aplicaciones y sistemas de base.

Las medidas de protección que se deberán considerar cubrir los siguientes aspectos:

- Prevención y detección de intrusiones ilegítimas, mediante sistemas IDS/IPS.
- Firewall de última generación (NGFW) para control de acceso y segmentación de red.
- Firewall de aplicaciones web (WAF) para la protección contra ataques dirigidos a aplicaciones.
- Escáner de vulnerabilidades para sistemas operativos, software del servidor y componentes críticos.
- Herramientas de análisis y escaneo de seguridad en aplicaciones para detectar vulnerabilidades en código y configuraciones.



- Prevención de pérdida de datos (DLP) para resguardar información confidencial y propiedad intelectual del MINSAL, en almacenamiento, uso y tránsito dentro de las dependencias del contratante o la red del proveedor.
- Protección antimalware y antivirus de última generación (EDR/XDR) para detección y respuesta ante amenazas avanzadas.
- Certificados digitales y mecanismos de autenticación robustos, incluyendo MFA para accesos críticos.
- Gestión de identidades y accesos (IAM) para controlar y auditar los privilegios de los usuarios.
- Monitorización y correlación de eventos de seguridad (SIEM/SOAR) para una respuesta eficaz ante incidentes.
- Seguridad en la nube, incluyendo cifrado, controles de acceso y auditoría en entornos *cloud*.
- Herramientas de conformidad y cumplimiento normativo, alineadas con los estándares de seguridad vigentes.

Las soluciones seleccionadas deberán cumplir con las mejores prácticas y normativas aplicables, garantizando una protección integral de los activos tecnológicos y la información del MINSAL.

10. INFRAESTRUCTURA PARA PRODUCCIÓN.

Los sistemas en producción deberán implementarse en un *datacenter* que cumpla con los estándares requeridos, conforme al grado de criticidad de la información, de manera tal que garantice la disponibilidad, integridad y confidencialidad de la información para los procesos que soporte.

En el caso de los sistemas de registro clínico electrónico, exámenes de laboratorio y sus informes, recetas médicas, e imágenes identificadas, cuya información es de carácter reservada, la infraestructura mínima es TIER III o superior (preferiblemente TIER IV), para garantizar redundancia y tolerancia a fallos⁴.

Tratándose de otros sistemas y aplicaciones, se determinará en cada caso los requerimientos de disponibilidad, acceso e integridad que requieran.

La solución debe estar conectada a través de la Red de Comunicaciones Privada de la institución contratante, asegurando la protección del tráfico mediante la implementación de *firewalls* perimetrales y de aplicación (WAF) segmentación de redes y monitoreo continuo del

⁴ Para las definiciones de las infraestructuras se deberán referir al estándar ANSI/TIA-942 y sus actualizaciones (*Telecommunications Infrastructure Standard for Data Centers Commercial Building*). Así como las exigencias establecidas en RIC 11 de la normativa SEC, que establece las condiciones de continuidad de servicio para los grupos 0,1 y 2 en los recintos de atención médica.





tráfico, que permitan filtrar, inspeccionar y restringir el acceso, garantizando que solo el tráfico legítimo y autorizado fluya entre la institución y terceros.

Adicionalmente, se deberán establecer reglas de control de acceso, utilizando soluciones de detección y prevención de intrusos (IDS/IPS) para mitigar posibles amenazas. Todo el tráfico deberá ser cifrado y autenticado para asegurar la integridad y confidencialidad de la información intercambiada.

11. GESTIÓN DE DATOS PRODUCTIVOS.

Debe existir un control estricto sobre las modificaciones que se realizan a nivel de datos de producción, que incluya al menos:

11.1. Identificación de la base de datos.

Todo sistema que incluya el tratamiento de datos personales deberá contar con un documento que señale al menos los siguientes aspectos:

- Responsable del tratamiento.
- Tipos de datos personales Categorías o que serán objeto de tratamiento.
- Tiempo mínimos y máximos de retención.
- Procesos de negocio en que se utilizarán los datos personales.
- Fuentes de datos personales que se consideran.
- Destinatarios de la información.

11.2. Calidad de Datos.

Siempre que el proveedor detecte que se haya producido un cambio que afecte o pueda afectar la calidad de datos productivos deberá informar a la contraparte técnica de la institución contratante, incluyendo el detalle del cambio, su origen, ya sea errores de ingresos de datos o incidencias de sistemas. Informe técnico de las causas que dieron lugar a los errores o incidencias de que se trate, incluyendo todos los antecedentes que permitan trazar la actividad que dio lugar al cambio, día y hora en que se produjeron, usuarios que participaron, bases de datos afectadas, procesos involucrados.

La calidad de los datos deberá ser verificada en todas las etapas del ciclo de tratamiento de la información, a fin de asegurar que cumpla con los estándares establecidos en cuanto a su veracidad y aspectos formales del registro.

En el caso de que se detecten falencias en la calidad de los datos, imputables al proveedor, ya sea durante los procesos de desarrollo, implementación o en las revisiones preventivas del aplicativo, se entenderá que las acciones correctivas necesarias forman parte de la garantía provista por el proveedor. Por tanto, dichas correcciones deberán ser realizadas por éste sin costo adicional para la Institución Contratante.



11.3. Procedimiento de modificación o restablecimiento de datos.

El proveedor no podrá adoptar decisiones en relación con la modificación de datos o al restablecimiento de datos modificados. A estos efectos se deberá contar con un procedimiento de solicitudes de análisis y calificación del cambio. Será de responsabilidad de la Contraparte institucional, calificar si procede o no hacer tales modificaciones, o bien escalará para lograr las justificaciones o autorizaciones del caso y, en caso de que proceda, otorgará la autorización final para proceder solo será generada por el MINSAL.

En caso de autorizarse el cambio o restablecimiento de datos, el proveedor deberá proporcionar los antecedentes que aseguren el respaldo de la intervención efectuada.

11.4. Procedimiento de notificación y reporte.

El proveedor o su representante institucional reportará aquellos casos en que sospeche que los datos de producción se encuentran en riesgo, proporcionando un informe detallado de los datos afectados, y las causas técnicas o de procesos que podrían impactar en la seguridad o calidad de los datos.

11.5. Migración de datos a nuevos sistemas o cambios de versiones de sistemas.

En el caso de que se deban implementar nuevos sistemas o nuevas versiones de sistemas, se adoptarán los resguardos que permitan preservar la calidad, integridad y disponibilidad de los datos. Por lo tanto, deberán realizarse los respaldos de la información que permitan su restablecimiento, copias de seguridad y procedimientos de gestión de cambio que aseguren estos objetivos, además de garantizar la continuidad de negocios.

11.6. Modelos de Datos.

Todo proveedor o institución colaboradora del sector salud, deberá poner a disposición de la contraparte técnica de la entidad contratante, los modelos de datos que permitan la adecuada gestión de los datos asociados a los procesos. Estos modelos serán parte de los entregables obligatorios de toda solución que la institución encargue a terceros, cualquiera sea el modelo contractual en base al cual se hayan desarrollado. Al término del contrato se deberán entregar las versiones actualizadas y vigentes.

11.7. Esquemas de metadatos.

Las bases de datos que se desarrollen deberán contar con esquemas de metadatos aprobados por MINSAL.

11.8. Calidad de tratamiento de datos.





Los datos personales tratados a través de los sistemas de salud corresponden a sus titulares. Su protección se encuentra garantizada en el artículo 19 Nos. 1 y 4 de la Constitución Política de la República de Chile.

Toda persona que entre en contacto con un dato personal de un tercero deberá guardar la debida diligencia en su procesamiento y custodia, haciéndose responsable de los daños y quiebres de seguridad.

En el tratamiento de datos debe respetar, además, la normativa aplicable en relación con el tratamiento de datos de salud, contenida en el DFL N° 1, de 2006 del Ministerio de Salud, la ley 20.584 de derechos y deberes del paciente, ley 20.120 sobre investigación científica en personas humanas, y las demás leyes y normativa complementaria del sector salud.

Los datos relativos a la salud tienen el carácter de sensible y por tanto sólo puede ser objeto de tratamiento en las hipótesis que prevé y autoriza el legislador o con el consentimiento de los titulares. En esta calidad habrá de adoptarse los siguientes resguardos:

11.9. Ejercicio de Derechos del Titular de Datos.

MINSAL debe cumplir con los derechos de las personas en relación con el tratamiento de datos personales. Todo proveedor e institución colaboradora tendrá a estos efectos el carácter de procesador o mandatario para el tratamiento de datos personales. Por lo tanto, MINSAL podrá formularle requerimientos que le permitan responder a los derechos de acceso, rectificación, supresión o cancelación, bloqueo, o portabilidad de datos personales, los cuales deberán ser respondidos dentro de las 8 horas hábiles siguientes desde que se comunique a la contraparte técnica respecto de la solicitud y la información que le permita al proveedor responder adecuadamente.

11.10. Mecanismos de control y seguimiento de datos.

El proveedor deberá implementar sistemas de acceso seguro a los datos, debiendo establecerse para cada usuario sólo los privilegios que le permitan acceder o realizar otras operaciones de tratamiento de datos que correspondan a sus perfiles de usuario o las condiciones legales de acceso, de acuerdo con sus competencias, tratándose de información sensible, como la información de salud de pacientes.

El proveedor deberá establecer mecanismos de comunicación segura de datos, cualquiera que sea el medio o técnica utilizada para su transferencia o comunicación desde el origen hasta el usuario requirente, utilizando mecanismos de seguridad consecuentes a un nivel alto de protección consistente con el medio en el cual se transferirá o comunicará la información.

Cualquiera que sea el medio o técnica de transferencia o comunicación de los datos, en el sistema deberá quedar registro auditable (log) con la identificación del usuario que accede a los datos (requirente), la descripción del contenido al que accede, el motivo o propósito del acceso y destinatario de la información. Esta información quedará a disposición del contratante de manera permanente.



**11.11. Formatos de salida.**

El proveedor deberá garantizar la seguridad de los archivos electrónicos en los formatos de salida, aplicando medidas de protección acorde con los estándares vigentes. Los que deberán cumplir con las siguientes disposiciones:

11.11.1. Reportes.

- Los reportes deberán generarse en formatos confiables que permitan la protección de la información, asegurando compatibilidad con mecanismos de cifrado.
- Cuando los reportes contengan datos sensibles o críticos, deberán almacenarse con cifrado AES-256 y acceso restringido según los privilegios del usuario autorizado.
- El acceso a los reportes estará sujeto a mecanismos de autenticación y autorización, garantizando que solo usuarios autorizados puedan visualizarlos o descargarlos.
- La descarga de reportes deberá implementarse con cifrado en tránsito (SSL/TLS) y mecanismos de verificación para evitar accesos no autorizados.

11.11.1.2. Descarga de archivos.

- Para datos utilizados en procesos automatizados o manuales, los archivos deberán entregarse en formatos estructurados (ejemplo: CSV cifrado, JSON o XML con protección criptográfica).
- Se debe aplicar cifrado de nivel de campo o de base de datos, garantizando la integridad y confidencialidad de la información.
- Antes de la carga o descarga de archivos, se deberán aplicar controles de autenticación y autorización según el perfil de acceso del usuario, evitando accesos indebidos.

11.11.1.3. Medio de transporte de Información.

Toda información transferida mediante dispositivos de almacenamiento móvil, correo electrónico o plataformas en la nube deberá estar protegida mediante un sistema de cifrado robusto.

Solo el solicitante o receptor autorizado podrá descifrar los datos, conforme al procedimiento establecido por el proveedor. Asimismo, queda estrictamente prohibido el envío de información sensible a direcciones de correo no institucionales.

11.12. Protección Criptográfica de Datos en Tránsito y Reposo:

**11.12.1. Cifrado de Datos Sensibles.**

Se deberán implementar mecanismos criptográficos robustos para proteger el acceso y almacenamiento de credenciales de usuario, bases de datos del sistema y la transmisión de información sensible.

11.12.2. Seguridad en la Transmisión de Datos.

- Todos los sitios y sistemas web deben cifrar las comunicaciones entre cliente y servidor utilizando HTTPS con certificados emitidos por entidades acreditadas en el país.
- Se debe emplear TLS 1.2 o superior como estándar mínimo para garantizar la seguridad en la transmisión de datos.

11.12.3. Cifrado en Reposo.

- Toda información almacenada debe estar protegida mediante AES-256 o RSA-4096, u otros algoritmos aprobados en la política de uso de criptografía.
- Se deben utilizar sistemas de gestión segura de claves criptográficas para su generación, almacenamiento y rotación periódica.

11.12.4. Protección de Contraseñas.

- El almacenamiento de contraseñas debe realizarse con algoritmos diseñados para resistir ataques de fuerza bruta, como *bcrypt*, *PBKDF2* y *Argon2*.

11.12.5. Monitoreo y Prevención de Vulneraciones.

- Se deben aplicar controles técnicos y administrativos para la detección temprana de intentos de vulneración del sistema de cifrado.
- Los sistemas deben estar configurados para seleccionar siempre la opción de cifrado más segura disponible.

11.12.6. Algoritmos no permitidos.

Algoritmos de *Hashing* Inseguros (para contraseñas)

- MD5 - Vulnerable a colisiones y ataques de fuerza bruta.
- SHA-1 - Débil ante ataques de colisión y preimagen.

Algoritmos de Cifrado Simétrico Débiles:

- DES (*Data Encryption Standard*) - Clave de 56 bits fácilmente rompible.
- 3DES (*Triple DES*) - Sus claves efectivas de 112 bits ya no son seguras ante ataques avanzados.
- RC4 (*Rivest Cipher 4*) - Débil ante ataques de sesgo y ya no es seguro para TLS.

Protocolos y Versiones Obsoletas de Cifrado



- TLS 1.0 / TLS 1.1 – Considerados inseguros y deshabilitados en la mayoría de los sistemas modernos.
- SSL 2.0 / SSL 3.0 – Vulnerables a múltiples ataques.

11.13. Supresión, cancelación o destrucción de datos.

- Toda modificación, cancelación o destrucción de datos debe realizarse de acuerdo con los estándares generalmente aceptados, siempre por instrucciones del mandante, debiendo dejarse acta de las operaciones realizadas.
- En su calidad de procesador o mandatario, el proveedor o la institución colaboradora será responsable de la ejecución del proceso, y de dejar constancia de los distintos pasos y resultados obtenidos.
- Los dispositivos digitales y magnéticos deben ser sometidos a procedimientos de formateo seguro antes de ser descartados.
- En los procesos de digitalización de información queda prohibido a los proveedores destruir o descartar los originales sin la autorización del mandante.
- Durante la operación del servicio por parte del proveedor, se debe considerar que se cumplan las políticas y procedimientos de gestión de incidentes establecidos durante la contratación, incluyendo la generación de registros de incidentes y su comunicación oportuna a las partes interesadas.

11.14. Política de reemplazo de medios magnéticos y de almacenamiento de información.

En el caso de reemplazos de medios magnéticos de almacenamiento de información, el proveedor deberá realizar un borrado permanente de la información almacenada una vez que esta haya sido restaurada en su completitud y certificada su integridad por la contraparte de MINSAL.

11.15. Mecanismos de control y trazabilidad.

Se deberán establecer mecanismos para medir al menos los siguientes aspectos:

- Cumplimiento de las medidas de seguridad acordadas.
- Cumplimiento de los niveles de servicio acordados.
- Cumplimiento de las políticas del prestador de servicios.
- Cumplimiento de las medidas asociadas a la destrucción de datos al final del contrato.

11.16. Tratamiento de los datos sensibles.





Toda persona que desarrolle labores para una institución del sector Salud, ya sea por contratación directa o indirecta deberá conocer las restricciones al tratamiento de los datos y de la información respecto a la cual tengan conocimiento con motivo del ejercicio de sus funciones, de acuerdo con la normativa general de salud, la ley 19.628 y las normas sectoriales.

El personal que trabajan en el tratamiento de los datos personales o sensibles estarán obligados a guardar secreto sobre el mismo, cuando provengan o hayan sido recolectados de fuentes no accesibles al público, como, asimismo, sobre los demás actos y antecedentes relacionados con ley 19.628 artículo 7°, sobre Protección a la Vida Privada. Por lo tanto, los datos personales o sensibles, indistintamente del medio en que estén contenidos, deberán ser protegidos y resguardados adecuadamente por quienes tienen el deber de manipularlos, garantizando razonablemente su privacidad a través de la implementación de procedimientos y controles para su tratamiento. En este contexto, los sistemas que procesen datos sensibles deberán cumplir con las siguientes reglas:

11.16.1. **Privacidad por defecto.**

Los sistemas y aplicaciones serán configurados de manera que el acceso a los datos sea restringido a las personas y usos previamente definidos, debiendo ejecutarse una acción consciente y trazable para cambiar el modelo de acceso a los datos. Adicionalmente, la gestión de datos incluirá técnicas de anonimización, seudonimización o encriptación de datos, de acuerdo con los requerimientos funcionales que se definan previamente.

11.16.2. **Seguridad en el diseño.**

Los sistemas y aplicaciones deberán ser desarrollados de forma tal que incluyan sistemas de verificación permanente de brechas de seguridad. Asimismo, los sistemas deberán estar diseñados para adoptar las medidas urgentes y necesarias para el resguardo de los datos personales en caso de un incidente de seguridad que pudiese afectarlos.

11.16.3. **Responsabilidad demostrable.**

Los sistemas y aplicaciones deben permitir la trazabilidad de todas las operaciones de tratamiento de datos personales, facilitando la verificación y demostración de dichas operaciones en cualquier momento. Esto incluye el registro de auditorías y el mantenimiento de logs de acceso.

11.16.4. **Segregación datos y de funciones.**

El diseño de los sistemas deberá considerar perfiles diferenciados por competencias, de forma tal que sólo puedan acceder a los datos personales los profesionales que se encuentren legalmente facultados para acceder a ellos. Asimismo, el procesamiento y almacenamiento de los datos debe ser segmentado en función de su clasificación de sensibilidad, minimizando el riesgo de acceso no autorizado.

12. ARQUITECTURA REFERENCIAL



Todo sistema desarrollado o implementado para el MINSAL, debe alinearse con la Arquitectura Referencial Ministerial establecida, que describe las directrices y estándares arquitectónicos de referencia. Esta arquitectura es fundamental para asegurar que las soluciones sean interoperables, escalables y fácilmente integrables en el entorno tecnológico existente. Para cumplir con esta cláusula, se deben considerar los siguientes puntos:

- **Alineación con la Estrategia Tecnológica:** Los sistemas deben diseñarse y desarrollarse de acuerdo con la visión y los objetivos tecnológicos establecidos en la arquitectura de referencia, garantizando que soporten las metas estratégicas y operativas de la organización.
- **Estándares y Tecnologías Aprobadas:** Los desarrollos deben seguir los estándares de tecnología, infraestructura y metodologías definidos en la arquitectura referencial, incluyendo el uso de plataformas, *frameworks* y patrones de diseño aprobados, con el fin de asegurar la uniformidad y la calidad en todas las aplicaciones.
- **Revisión y Aprobación:** Cualquier cambio significativo en la arquitectura del sistema propuesto debe ser revisado y aprobado por el Jefe TIC o equipo encargado de la gobernanza de la arquitectura, para garantizar su compatibilidad y minimización de riesgos.
- **Reutilización y Modularidad:** Se debe promover el diseño modular y la reutilización de componentes para facilitar la escalabilidad, reducir la duplicación de esfuerzos, y optimizar el uso de recursos y tiempo en desarrollos futuros.
- **Documentación y Actualización Continua:** Es obligatorio documentar las arquitecturas de los sistemas desarrollados y los modelos de datos, debiéndose mantener esta documentación actualizada en cada fase de implementación, de manera que se facilite su integración y mantenimiento a largo plazo.

13. INTEROPERABILIDAD.

Todos los sistemas y aplicaciones desarrollados para una institución del sector de la salud, deben cumplir con los requisitos de interoperabilidad definidos, con el fin de garantizar que puedan interactuar eficazmente con otros sistemas internos y externos, facilitando la integración de datos y procesos de negocio. Esta interoperabilidad es fundamental para optimizar la eficiencia, mejorar la toma de decisiones y asegurar una experiencia de usuario consistente. Para lograr esto, se establecen las siguientes directrices:

- **Cumplimiento de Estándares HL7:** Los sistemas deben ser compatibles con el estándar HL7 (*Health Level Seven*) en sus versiones vigentes, incluyendo HL7 v2.x y FHIR (*Fast Healthcare Interoperability Resources*), este último en sus versiones R4 y posteriores, para asegurar un intercambio de datos entre sistemas de información de salud que respete la consistencia y precisión clínica. Esto permitirá la interoperabilidad eficaz de información





entre sistemas de historia clínica electrónica (HCE), sistemas de apoyo clínico (RIS, LIS, etc.) y otras aplicaciones de salud.

- **Estándares de Integración y Protocolos:** Los sistemas deben utilizar estándares de integración ampliamente aceptados (como REST, GraphQL, JSON, XML) y protocolos de comunicación seguros (como HTTPS, SFTP y TCP/IP) que permitan la transmisión de datos de manera confiable y segura entre sistemas de información de salud.
- **APIs Documentadas y Consistentes:** Es obligatorio desarrollar APIs (interfaces de programación de aplicaciones) documentadas y consistentes, que faciliten el acceso y la integración de funcionalidades y datos entre diferentes sistemas de información de salud, tanto internos como de terceros, asegurando una comunicación clara y eficaz.
- **Compatibilidad con la Arquitectura Empresarial:** Todos los desarrollos deben diseñarse para ser compatibles con la arquitectura institucional existente y futura de la organización, considerando los lineamientos normativos y plataformas habilitadoras que permitan una integración coherente de los sistemas en el ecosistema tecnológico.
- **Gestión de Datos Interoperables:** Los datos deben manejarse en formatos estructurados y normalizados según las directrices organizacionales y normativas vigentes, permitiendo su fácil intercambio y procesamiento entre aplicaciones sin pérdida de consistencia o integridad de la información.
- **Pruebas de Interoperabilidad:** Durante el proceso de desarrollo, es indispensable realizar pruebas que permitan evaluar la capacidad de los sistemas, dispositivos o aplicaciones para interactuar e intercambiar información de forma efectiva y que cumpla con los requisitos de conectividad, rendimiento y seguridad confiable y consistente al interactuar con otras plataformas y sistemas.

14. USO DE INTELIGENCIA ARTIFICIAL (IA).

Si en el marco de la contratación, se requiera implementación de modelos de IA, el proveedor se compromete a utilizar tecnologías de Inteligencia Artificial (IA) de acuerdo con los más altos estándares éticos, legales y de seguridad, garantizando que su implementación y uso no comprometan la integridad, privacidad, ni la seguridad de los datos procesados en el marco del contrato.

- El proveedor garantizará que los algoritmos de IA utilizados sean auditables y explicables. En caso de ser necesario, deberá proporcionar detalles comprensibles sobre el funcionamiento y la toma de decisiones de los sistemas de IA implementados, asegurando que las partes interesadas puedan entender los resultados y decisiones generadas por dichos sistemas.
- El uso de IA deberá ajustarse estrictamente a las leyes de seguridad de la información y protección de datos aplicables, incluidas la Ley N° 21.663 sobre Ciberseguridad, la Ley N° 19.628, sobre Protección de Datos Personales, la Ley N° 20.584 de derechos y Deberes de





los pacientes, además de sus normas reglamentarias y técnicas que las complementan, entre otras normativas vigentes.

- La entidad responsable debe resguardar que todo proyecto que incluya IA cumpla con lo previsto en la Circular N°711/2023, de SEGPRES sobre Lineamientos para el Uso de Herramientas de IA en el Sector Público.
- El proveedor implementará medidas de seguridad adecuadas para proteger la confidencialidad e integridad de los datos utilizados por los sistemas de IA.
- El proveedor realizará evaluaciones periódicas de riesgos asociados al uso de IA, incluyendo impactos potenciales sobre la seguridad, la privacidad, y la equidad en la toma de decisiones. Además, se compromete a implementar mecanismos de supervisión para asegurar que la IA no genere resultados sesgados, discriminatorios ni dañosos.
- El proveedor garantizará que los usuarios tengan acceso a mecanismos para cuestionar, corregir o revertir decisiones automatizadas que hayan sido tomadas por sistemas de IA. Asimismo, se asegurará de que los usuarios puedan ejercer sus derechos de acceso, rectificación, cancelación y oposición, cuando corresponda.
- El proveedor se comprometerá a cumplir con todas las regulaciones nacionales e internacionales aplicables sobre el uso de IA, incluyendo la normativa sobre ética en inteligencia artificial y cualquier otro requisito legal relacionado con la implementación y uso de estas tecnologías en el ámbito de la salud.
- Se entenderá que el proveedor asume plena responsabilidad por el uso y los resultados generados por la IA, comprometiéndose a corregir cualquier error, vulnerabilidad o perjuicio que derive de su implementación, asegurando la reparación o mitigación de cualquier daño generado.

15. ENTREGA DE SISTEMAS Y DATOS AL TÉRMINO DEL CONTRATO.

Como actividad de cierre de contrato y cumpliendo con el compromiso de garantizar la continuidad de servicio, el Proveedor deberá efectuar todas las actividades necesarias para dejar operativos los aplicativos, bases de datos y software base en la plataforma que disponga el contratante, equivalente a la que se encuentre en operación en ese momento.

Para ello, tanto los colaboradores como los proveedores salientes deberán realizar al menos las siguientes actividades:

- Entrega de la totalidad de la información pertinente que el MINSAL o terceros determinados el Ministerio, tales como proveedores entrantes le requieran para garantizar la continuidad operacional.
- Entrega de todos los datos que son tratados por el sistema en un formato estructurado que permita mantener las relaciones entre tablas, datos maestros, librerías y demás aspectos esenciales para su portabilidad a un nuevo sistema; las aplicaciones funcionando y envasadas, junto con procedimientos de instalación garantizados.





- Entrega de todos los componentes necesarios que hagan posible su migración y almacenamiento histórico, como el modelo de datos, arquitectura, librerías, *frameworks* utilizados, etc., con el fin de garantizar la continuidad de servicio.
- La especificación de cada componente del sistema, incluyendo los diccionarios de datos.
- El MINSAL podrá requerir que el Proveedor deje el ambiente operativo funcionando y con procedimientos de instalación de plataforma de software garantizado, o el ambiente operativo y las aplicaciones y los datos instalados en una plataforma diferente, pero equivalente a la de la operación vigente.
- Cualquier otro elemento necesario para mantener la continuidad operacional del MINSAL de manera comparable al período de vigencia del contrato correspondiente.
- Una vez que se reciban los datos por MINSAL, la contraparte institucional dará la orden de cancelación de los datos que se encuentren almacenados en los sistemas del proveedor, lo que deberá ejecutarse sin dilaciones indebidas por éste.

16. NORMATIVA SOBRE SEGURIDAD DE LA INFORMACION.

El proveedor deberá dar cumplimiento a la normativa vigente aplicable al contrato, durante toda su vigencia. En especial deberá dar cumplimiento a los siguientes cuerpos normativos:

16.1. Normativa del sector salud.

- DFL N° 1, de 24 de abril de 2006, Ministerio de Salud, que fija el texto refundido, coordinado y sistematizado del Decreto Ley N° 2.763, de 1979 y de las leyes N° 18.933 y 18.469;
- DFL N° 725, Ministerio de Salud, Código Sanitario;
- Ley N° 19.966, de 2004, que establece un régimen de garantías de salud;
- Ley N° 19.650, que perfecciona normas del área de la salud;
- Ley N° 20.120 de 22 de septiembre de 2006, sobre la investigación científica en el ser humano, su genoma, y prohíbe la clonación humana y demás normativa del área de la salud.
- Ley N° 20.584, referida a Deberes y Derechos que tienen las Personas en relación con acciones vinculadas a su Atención de Salud;
- Ley N° 20.724, de 2014, que modifica el Código Sanitario en materia de regulación de medicamentos;
- Ley N° 20.850, de 2016, que crea un sistema de protección financiera para diagnósticos y tratamientos de alto costo y rinde homenaje póstumo a don Luis Ricarte Soto Gallegos;
- Ley N° 21.258, de 2020, que crea la ley nacional del cáncer, que rinde homenaje póstumo al doctor Claudio Mora.
- Ley 21.541, de 17 de marzo de 2023, que modifica la normativa que indica para autorizar a los prestadores de salud a efectuar atenciones mediante telemedicina.
- Decreto N° 41, de 24 de julio de 2012, del Ministerio de Salud, Reglamento de Ficha Clínica;





- Decreto N° 31 de 15 de junio de 2012, del Ministerio de Salud, Reglamento sobre entrega de información y expresión de consentimiento informado en las atenciones de salud;
- Decreto N° 38, de 2005, del Ministerio de Salud, Reglamento Orgánico de los establecimientos de salud de menor complejidad y de los establecimientos de autogestión en red.
- Decreto N° 38, de 26 de diciembre de 2012, del Ministerio de Salud, que aprueba Reglamento sobre derechos y deberes de las personas en relación con las actividades vinculadas con su atención de salud.
- Decreto N° 38, de 2013, del Ministerio de Salud, que modifica decreto N° 466 de 1984, Reglamento de Farmacias, Droguerías, almacenes farmacéuticos, botiquines y depósitos autorizados.
- Decreto N° 6, de 16 de abril de 2021, del Ministerio de Salud, Reglamento sobre acciones de vinculadas a la atención de salud realizadas a distancia.
- Decreto N° 820, 2011, Ministerio de Salud.

16.2. En materia de documentos electrónicos.

- Ley N°19.880/2003: Ley que establece bases de los procedimientos administrativos que rigen los actos de los órganos de la administración del Estado. Esta ley es importante porque establece condiciones sobre los plazos y la forma en que los servicios públicos deben responder frente a requerimientos de ciudadanos y de otros servicios públicos.
- Ley N° 21.180, de transformación digital del Estado.
- Ley N° 19.799 de 12 de abril de 2002, de firmas y documentos electrónicos.
- Decreto N° 181, que aprueba Reglamento de la ley N° 19799 sobre documentos electrónicos. Firma electrónica y la certificación de dicha firma.
- Decreto N°83, de 2005, del Ministerio secretaría General de la Presidencia,
- Decreto N° 14, de 2014, del Ministerio secretaría General de la Presidencia, el decreto N° 1 de 2015, del Ministerio secretaría General de la Presidencia.
- Decreto N° 4, 2021, Ministerio Secretaría General de la Presidencia, Reglamento que regula la forma en que los procedimientos administrativos deberán expresarse a través de medios electrónicos, en las materias que indica, según lo dispuesto en la ley N° 21.180 sobre transformación digital del estado.
- Decreto N° 24, 2019, Ministerio de Economía, que aprueba norma técnica para la prestación del servicio de certificación de firma electrónica avanzada.
- Decreto N° 1, 2015, Ministerio Secretaría General de la Presidencia, aprueba norma técnica sobre sistemas y sitios web de los órganos de la administración del estado.

16.3. En materia de seguridad de la información.

INSTRUCTIVO SOBRE CLÁUSULAS DE PROTECCIÓN DE DATOS Y SEGURIDAD DE LA INFORMACIÓN DEL SECTOR SALUD				
	Sistema de Gestión de Seguridad de la Información - Minsal			
	MINISTERIO DE SALUD	ITS-NC- 006	Versión: 5	Página 44 de 46
				TLP:BLANCO

- Ley N° 21.663 sobre Marco de Ciberseguridad, esta ley proporciona un marco para asegurar la ciberseguridad de infraestructuras críticas.
- Decreto N° 295, de 2024, del Ministerio del Interior y Seguridad Pública: Aprueba reglamento de reporte de incidentes de ciberseguridad de la ley N° 21.633.
- Decreto N°483, de 2024, del Ministerio del Interior y Seguridad Pública: Aprueba Reglamento que determina la estructura interna de la Agencia Nacional de Ciberseguridad.
- Decreto N°164, de 2023, del Ministerio del Interior y Seguridad Pública: Aprueba Política Nacional de Ciberseguridad 2023-2028.
- Decreto Supremo N° 7 establece una Norma Técnica de Seguridad de la Información y Ciberseguridad, en concordancia con la Ley N° 21.180 sobre Transformación Digital del Estado. Que tiene el objetivo de definir estándares mínimos de seguridad y ciberseguridad para todos los órganos de la administración pública en Chile
- Decreto N° 533 establece el marco regulatorio en ciberseguridad para las instituciones públicas en Chile, que incluye normas para la protección de la información, la gestión de incidentes de ciberseguridad y la protección de infraestructuras críticas, en las que se procesan datos personales.
- Decreto Supremo N° 83, 2005, Aprueba norma técnica para los órganos de la administración del estado, sobre seguridad y confidencialidad de los documentos electrónicos.
- Decreto N°273, 2022, Ministerio del Interior y Seguridad Pública, Establece obligación de reportar incidentes de ciberseguridad.
- Resolución Exenta N°372/2025 que aprueba texto de las recomendaciones del Consejo para la Transparencia sobre Transparencia Algorítmica y Oficio N°7286/2025 Guía del Consejo para la Transparencia para la adopción de las Recomendaciones sobre Transparencia Algorítmica.
- Circular N° 711/2023 establece lineamientos sobre el uso de herramientas de inteligencia artificial (IA) en el sector público de Chile, proporcionando directrices para una implementación ética, segura y transparente de estas tecnologías en servicios gubernamentales. Con el objetivo de asegurar que las aplicaciones de IA en el sector público se alineen con los valores de protección de derechos, transparencia y seguridad de la información, además de fomentar la eficiencia y mejorar la calidad de los servicios público.

16.4. En materia de protección de datos personales.

- Art. 19 Nos. 1 y 4 de la Constitución Política de la República.
- Ley N°19.628/1999: Sobre protección de la vida privada, que define dato personal, dato personal sensible, y establece las condiciones debe cumplir toda entidad que maneje estos datos. Algunos servicios públicos manejan datos personales o sensibles; en estos





servicios, el conocimiento de esta ley para el encargado de ciberseguridad es fundamental.

- Ley N° 21.719/2024: Que modifica la ley N° 19.628, sustituyendo su nombre por “Ley de Protección de Datos Personales” y actualiza las normas de este cuerpo normativo de acuerdo con los estándares actualmente vigentes. Esta ley entra en vigor el 1 de diciembre de 2026.
- Ley N° 20.575 sobre el principio de finalidad en el tratamiento de datos personales.
- Decreto N° 779, de 2000, que Aprueba Reglamento del Registro de Bancos de Datos Personales a cargo de organismos públicos.
- Resolución Exenta N° 489, 2022, Consejo para la Transparencia, Aprueba procedimiento para la tramitación de solicitudes de ejercicio de derechos de la ley N° 19.628, sobre protección a la vida privada.

16.5. En materia de delitos informáticos.

- Ley N° 21.459/2022: Establece normas sobre delitos informáticos, deroga la Ley N° 19.223 y modifica otros cuerpos legales con el objeto de adecuarlos al Convenio de Budapest. Esta ley establece los delitos informáticos reconocidos en Chile.
- Ley N° 20.009, sobre clonación de tarjetas de crédito.
- Decreto N° 83, de 2017, que promulgó el Convenio de Budapest en Chile. Tratado internacional de combate contra la ciberdelincuencia.

16.6. En materia de propiedad Intelectual.

- Ley N° 19.039, de Propiedad Industrial
- Ley N° 17.336, de Propiedad Intelectual. Fija condiciones para la protección de los programas computacionales como propiedad intelectual de sus autores.

16.7. Normas de aplicación general.

- Ley 21.542, Que modifica la carta fundamental con el objeto de permitir la protección de infraestructura crítica por parte de las fuerzas armadas, en caso de peligro grave o inminente
- Ley N° 21.180, de transformación digital del Estado;
- Ley N° 19.880 de bases de los procedimientos administrativos;
- Ley N° 20.285 de transparencia y acceso a la información pública;
- Ley N° 19.886 de compras públicas.
- Decreto N° 250, de 2005, del Ministerio de Hacienda, Reglamento de Compras Públicas.
- Resolución Exenta N° 619 – B de 26 de noviembre de 2018, de la Dirección de Compras y Contratación Pública





En caso de que alguna de estas normas sea modificada o sustituida el proveedor deberá adaptarse a los requerimientos de la nueva normativa.

17. MECANISMO DE DIFUSIÓN.

La comunicación de la presente política se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en el sitio web Minsal http://www.Minsal.cl/seguridad_de_la_informacion/
- Publicación en la intranet de Minsal <http://isalud.Minsal.cl/>
- Correo informativo.

18. HISTORIAL Y CONTROL DE VERSIONES

Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
01	Abril 2017	Todas	Creación del documento
02	Marzo 2019		Actualización de la referencianormativa
03	Marzo 2020	Directrices, normativa, excepciones al cumplimiento de la política	Actualización del documento y normativa 27001:2013
04	Noviembre 2022	Pag 2, 4-5, 6,9 Normativa ISO 27002:2022, Leyes y decretos, Periodo revisión Responsabilidades, Excepciones	Actualización Normativa ISO 27002:2022
05	Marzo 2025	Pag.5.8.9.16. 18. 25. 27.30.33 Preámbulo, Cumplimiento, Definiciones, Gestiona de Seguridad, Propiedad Intelectual, Alojamiento de datos en Cloud, Herramientas de Seguridad, Gestión de Datos Productivos, Arquitectura Referencial, Interoperatividad, IA, Normativa, Mecanismo de Difusión	Actualización general del documento, a los estándares internacionales a sus últimas versiones y normativa nacional sobre ciberseguridad.

